CEH v13 AI (312-50) Study Guide

Module 02: Footprinting and Reconnaissance

Exam-focused study guide built from the official theory video screenshots. ADDED CONTEXT marks content from outside the screenshots; verify marks facts to double check.

Table of Contents

1. Module at a Glance 4
2. Big Picture Map 6
3. Topic-by-Topic Guide 7
   - 3.1 Learning Objectives of Module 02 7
   - 3.2 Reconnaissance and the Two Types of Reconnaissance 7
   - 3.3 Information Obtained in Footprinting 9
   - 3.4 Footprinting Methodology 10
   - 3.5 Footprinting Using Advanced Google Hacking Techniques 12
   - 3.6 Footprinting through Search Engines 14
   - 3.7 Footprinting Using Advanced Google Hacking Techniques with AI 15
   - 3.8 Footprinting through SHODAN Search Engine 17
   - 3.9 Natural-Language Search vs Operator Search (Google Webcam Demo) 19
   - 3.10 Finding a Company's Top-Level Domains (TLDs) and Sub-domains 20
   - 3.11 Finding TLDs and Sub-domains with AI 21
   - 3.12 Extracting Website Information from archive.org (Wayback Machine and Photon) 23
   - 3.13 Footprinting through People Search Services and Job Sites 24
   - 3.14 Dark Web Footprinting 25
   - 3.15 Competitive Intelligence Gathering 26
   - 3.16 Other Techniques for Footprinting through Internet Research Services 27
   - 3.17 Harvesting Email Lists (theHarvester, Email Spider) with AI 29
   - 3.18 Analyzing Target Social Media Presence (BuzzSumo, Google Trends, Hashatit) 30
   - 3.19 Tools for Footprinting through Social Networking Sites (Sherlock, Social Searcher) 31
   - 3.20 Footprinting through Social Networking Sites with AI 32
   - 3.21 Whois Lookup 33
   - 3.22 Extracting DNS Information 35
   - 3.23 Finding IP Geolocation Information 37
   - 3.24 DNS Lookup with AI (DNSRecon) 38
   - 3.25 Reverse DNS Lookup 39
   - 3.26 Traceroute 41
   - 3.27 Traceroute with AI 42
   - 3.28 Traceroute Analysis 43
   - 3.29 Tracking Email Communications 44
   - 3.30 Footprinting through Social Engineering 46
   - 3.31 Footprinting Tools: Maltego and Recon-ng 47
   - 3.32 Footprinting Tools: OSINT Framework and Other Tools 49
   - 3.33 Collecting Information through Social Engineering on Social Networking Sites 51
   - 3.34 Footprinting Tools: FOCA and subfinder 52
   - 3.35 AI-Powered OSINT Tools 53
   - 3.36 Footprinting Countermeasures (Part 1) 55
   - 3.37 Create and Run a Custom Python Script to Automate Footprinting Tasks with AI 56
   - 3.38 Footprinting Countermeasures (Cont'd) 57
4. Tool Encyclopedia 59
   - 4.1 Search Engines and Device Search 59

4.2 Domains, Sub-domains and Websites ... 59
4.3 People, Business, Finance and Alerts ... 60
4.4 Social Media, Email and Dark Web ... 61
4.5 Whois, Geolocation, DNS and Network ... 61
4.6 Frameworks, Metadata and AI ... 62
5. Command Sheet ... 64
5.1 ShellGPT (sgpt) ... 64
5.2 Google Operator Queries and the lynx Pipeline ... 65
5.3 Sublist3r ... 65
5.4 dig ... 66
5.5 nslookup and host (ADDED CONTEXT) ... 67
5.6 Photon ... 68
5.7 theHarvester ... 69
5.8 Sherlock ... 69
5.9 whois (ADDED CONTEXT) ... 70
5.10 DNSRecon ... 71
5.11 tracert (Windows) ... 72
5.12 traceroute (Linux) and tcptraceroute ... 72
5.13 Recon-ng ... 73
5.14 subfinder ... 74
5.15 whatweb ... 74
6. Ports, Protocols, Standards and Acronyms ... 76
6.1 Protocols and Ports ... 76
6.2 DNS Record Types ... 77
6.3 Regional Internet Registries ... 77
6.4 Acronyms ... 77
7. Attack vs Countermeasure and Look-alike Comparisons ... 80
7.1 Footprinting Technique vs Countermeasure ... 80
7.2 Look-alike Pairs ... 80
8. Exam Cheat Sheet ... 82
8.1 Keyword -> Answer ... 82
8.2 Must-memorize Lists and Numbers ... 83
8.3 "Pick the BEST option" Rules for This Module ... 83
9. Practice Questions ... 85
10. Flashcards ... 95
11. Glossary ... 98
12. Coverage Report ... 100
12.1 Page to Section Map ... 100
12.2 [UNCLEAR] Items ... 101
12.3 Items to Double Check ... 101
12.4 Confirmation ... 101

Source: 14 pages of screenshots from the official Module 02 theory videos (slides 2 to 53). Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources. Items marked [UNCLEAR on page N] were too small or blurry to read with full confidence.

1. Module at a Glance

Module: 02 - Footprinting and Reconnaissance (EC-Council CEH v13 AI).

What this module is (5 lines):

1. It defines reconnaissance (footprinting), the first of the five hacking phases, and splits it into passive and active.
2. It lists what an attacker wants to learn: organization, network, and system information.
3. It walks through the footprinting methodology: search engines, internet research services, social networking sites, Whois, DNS, network and email, and social engineering.
4. It shows the main tools (Google operators, SHODAN, Netcraft, theHarvester, Sherlock, Whois, DNSRecon, traceroute, Maltego, Recon-ng, FOCA, subfinder, OSINT Framework) and how AI (ChatGPT, ShellGPT, Taranis AI) automates them.
5. It ends with countermeasures that reduce what an organization leaks to the public.

Why it matters: Every attack starts here. The quality of the recon decides the quality of every later phase. On the exam, Module 02 gives many "which tool" and "which operator" questions that are easy marks if you know the tool list.

What the exam usually asks from it:

- Is an activity passive or active footprinting?
- Which Google advanced operator does a given job (site:, filetype:, inurl:, intitle:, cache:, related:, info:)?
- Which tool fits a task: SHODAN (internet devices), Netcraft (sub-domains and OS), theHarvester (emails), Sherlock (usernames), Maltego (relationships), Recon-ng (modular framework), FOCA (document metadata), Photon (archived URLs), subfinder or Sublist3r (sub-domains).
- What a DNS record type means (A, MX, NS, CNAME, SOA, PTR, SRV, RP, HINFO, TXT).
- What a Whois lookup returns and which RIR covers which region.
- How traceroute works (TTL) and how to read traceroute output to find routers and firewalls.
- What an email header reveals.
- Which countermeasure stops a given leak (restrict zone transfer, split DNS, Whois privacy, disable directory listing, remove geo-tags).

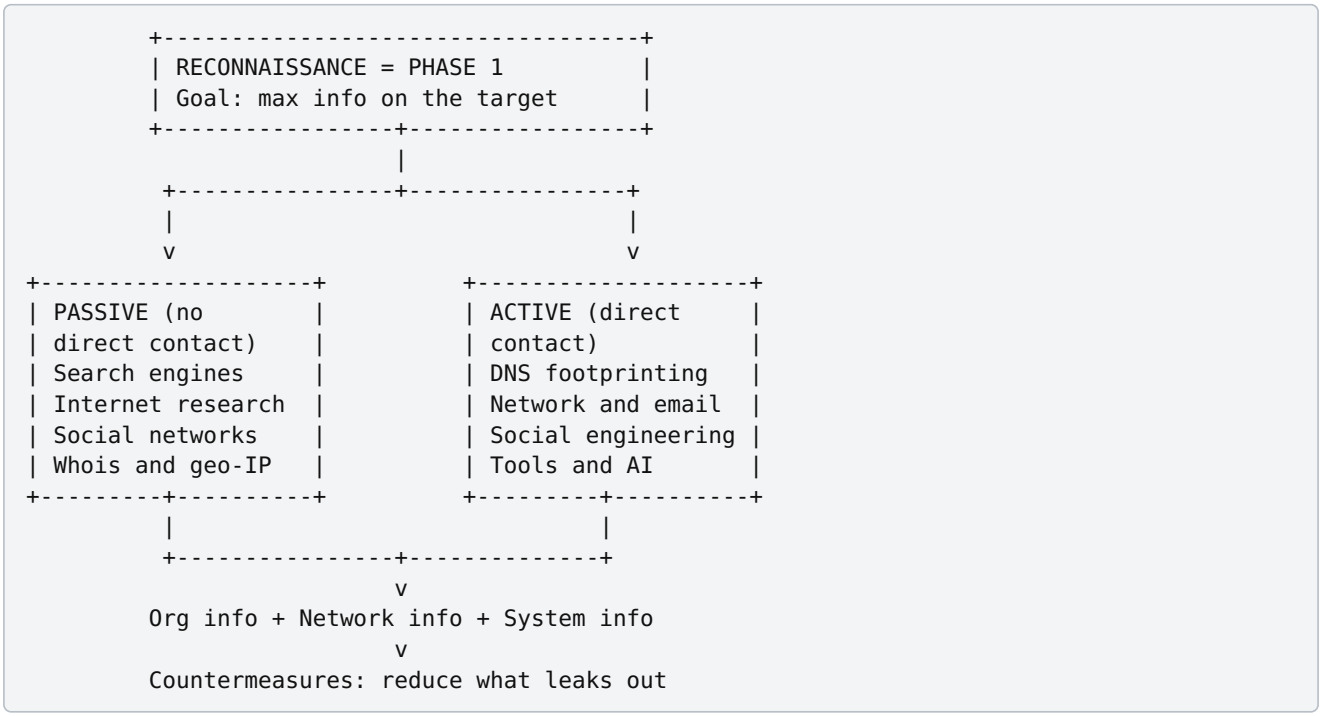
The 10 things to remember most:

1. Reconnaissance = footprinting = phase 1. Goal: gather as much information as possible about the target of evaluation before the attack.

2. Passive = no direct contact with the target (OSINT, paid databases, shared intel). Active = direct contact (DNS interrogation, social engineering, port scanning, user enumeration).
3. Three information groups: Organization, Network, System.
4. Google operators: site: (one domain), filetype: (file type), inurl: / allinurl: (words in URL), intitle: / allintitle: (words in title), cache:, link:, related:, info:, location:.
5. SHODAN searches for internet-connected devices (webcams, routers, ICS, servers) by banner, not web pages.
6. Whois data is held by five RIRs: ARIN (North America), RIPE NCC (Europe, Middle East, Central Asia), APNIC (Asia Pacific), LACNIC (Latin America, Caribbean), AFRINIC (Africa).
7. DNS records: A (IP), MX (mail), NS (name server), CNAME (alias), SOA (authority), PTR (reverse), SRV (service), RP (responsible person), HINFO (CPU and OS), TXT (text).
8. Traceroute uses the TTL field. Each router that drops a packet with TTL 0 sends back ICMP "time exceeded", which reveals its address. Windows tracert = ICMP; Linux traceroute = UDP by default.
9. Tool to purpose: theHarvester = emails and hosts; Sherlock = usernames on social sites; Maltego = relationship graphs; Recon-ng = modular web recon framework; FOCA = metadata in documents; Photon = crawler with archive.org URLs; subfinder = passive sub-domain discovery.
10. Key countermeasures: restrict DNS zone transfer, use split DNS, use Whois privacy, disable directory listing, remove geo-tags, train staff against social engineering, limit what is published.

2. Big Picture Map

The module follows one flow: decide the type of recon, know what you want, then collect it through passive sources first and active sources second, with tools and AI to automate. Defense closes the loop.



How each method maps to the information it gives:

Method	Main tools	Main output
Search engines	Google operators, GHDB, SHODAN	Files, login pages, devices
Internet research	Netcraft, archive.org, Spokeo, Dice	Sub-domains, old pages, people
Social networking	Sherlock, BuzzSumo, Social Searcher	Usernames, interests, contacts
Whois and geo-IP	DomainTools, IP2Location	Owner, NetRange, location
DNS	DNSRecon, SecurityTrails, dig	Hosts, mail servers, records
Network and email	traceroute, email headers	Routers, firewalls, sender IP
Social engineering	Eavesdropping, dumpster diving	Passwords, layouts, versions
Tools and AI	Maltego, Recon-ng, FOCA, sgpt	Graphs, automation, metadata

3. Topic-by-Topic Guide

The topics below follow the order of the screenshots.

3.1 Learning Objectives of Module 02

What it is: The opening slide lists ten goals for the module. They are also the skeleton of this guide.

1. Explain footprinting concepts.
2. Demonstrate footprinting through search engines.
3. Demonstrate footprinting through internet research services.
4. Demonstrate footprinting through social networking sites.
5. Use different techniques for Whois footprinting.
6. Use different techniques for DNS footprinting.
7. Use different techniques for network and email footprinting.
8. Demonstrate footprinting through social engineering.
9. Automate footprinting tasks using advanced tools and AI.
10. Explain footprinting countermeasures.

EXAM FOCUS: The objectives tell you the question pools: concepts, search engines, research services, social networks, Whois, DNS, network and email, social engineering, tools and AI, and countermeasures. Expect at least one question from each.

Memory trick: "Smart Researchers Search Whole Domains, Networks, and Social Tools Carefully" -> Search engines, Research services, Social networks, Whois, DNS, Network/email, Social engineering, Tools/AI, Countermeasures (after Concepts).

3.2 Reconnaissance and the Two Types of Reconnaissance

What it is (simple words): Reconnaissance, also called footprinting, is the preparation phase. The attacker collects as much information as possible about the target before attacking. The target is called the target of evaluation.

- **Target of evaluation (TOE):** the system, network, or organization being assessed or attacked.
- **Footprint:** the full picture of a target's online and physical presence, built from collected data.

Analogy: A burglar watches a house for a week before a break-in. He notes when the owners leave, where the cameras are, and which window has a weak lock. Watching from across the street is passive. Ringing the doorbell pretending to sell something is active.

How it works (numbered steps):

1. Define the target (domain, company, person) and the scope agreed with the client.
2. Collect passively first: public websites, search engines, social media, Whois, paid databases.
3. Move to active collection only when needed: query the target's DNS servers, talk to staff, scan ports.
4. Organize the data into organization, network, and system information.
5. Analyze it to find weak points and plan the next phases (scanning, enumeration, gaining access).

The two types:

Type	Meaning	Activities in notes	Detection risk
Passive	No direct interaction with target	OSINT, paid databases, shared intel	Very low
Active	Direct interaction with target	DNS interrogation, SE, port scan	Higher

Passive reconnaissance involves:

- **Open-source intelligence (OSINT) gathering:** collecting information that anyone can legally access, such as websites, news, social media, and public records.
- **Proprietary databases and paid services:** commercial data sources, such as business information services and people search services that charge a fee.
- **Sharing intelligence with partner organizations or industry groups:** getting threat or target data from trusted partners, for example an industry information sharing group.

Active reconnaissance involves:

- **DNS interrogation:** sending queries directly to the target's DNS servers to pull records.
- **Social engineering:** talking to or tricking the target's people to get information.
- **Network/port scanning:** sending packets to target systems to see which hosts and ports respond.
- **User and service enumeration:** asking the target's services for lists of users, shares, and services.

Real-world use: A pentester hired by a bank spends day one on passive recon. She reads job ads, LinkedIn profiles, and Whois data. The bank's security team sees nothing. On day two, with written approval, she queries the bank's DNS servers and calls the help desk. These actions can show up in logs. Result: a target list for the scanning phase.

Tools and commands used here: None specific; the rest of the module provides them.

AI angle: AI chatbots speed up passive recon by summarizing public data and writing search queries. Example prompt: "List public sources where I can find information about the IT infrastructure of example.com for an authorized assessment."

Countermeasures and defense: Limit public information; monitor for DNS queries and scans that signal active recon.

> **EXAM TIP:** If the scenario says the attacker "did not interact with the target" or used "publicly available sources", the answer is passive. If packets or people from the target were contacted, it is active.

> **TRAP:** Searching a public DNS lookup website is passive. Querying the target's own DNS server is active (DNS interrogation). Social engineering is active, even though no packets are sent.

EXAM FOCUS:

- How it is asked: "Which of the following is a passive footprinting technique?" or "An attacker called the help desk. Which type of recon is this?"
- Keywords: "without direct interaction", "publicly available" -> passive. "Queried the DNS server", "called", "scanned" -> active.
- Look-alike: Reconnaissance vs Scanning. Port scanning is listed in the notes as active reconnaissance, but in the five-phase model scanning is its own phase (phase 2). If a question asks for the phase, choose Scanning; if it asks for passive vs active recon, choose Active.

Memory trick: "Passive = Peek. Active = Ask." Passive just peeks at public data. Active asks the target directly.

3.3 Information Obtained in Footprinting

What it is: The slide groups the information an attacker wants into three buckets: organization, network, and system.

Analogy: Think of a spy file on a company. One page is about the people and offices (organization). One page is about roads and gates (network). One page is about the safes and locks (systems).

Organization information	Network information	System information
Employee details	Domain and sub-domains	Web server OS
Telephone numbers	Network blocks	Location of web servers
Branch and location details	Network topology	Publicly available email addresses
Background of the organization	Trusted routers and firewalls	Usernames and passwords

Organization information	Network information	System information
Web technologies	IP addresses of reachable systems	
News articles, press releases	Whois records	
Related documents	DNS records	

Key terms:

- **Network block (netblock):** a range of IP addresses owned by one organization, for example 192.0.2.0/24.
- **Network topology:** the layout of the network: which devices connect to which.
- **Trusted routers:** routers that the network trusts for routing and access decisions; if found, they become targets.
- **Web technologies:** the software a website uses (web server, CMS such as WordPress, frameworks, analytics).

How it works:

1. Organization data feeds social engineering (names, phones, roles).
2. Network data feeds scanning (IP ranges, domains, topology).
3. System data feeds exploitation (OS versions, usernames, leaked passwords).

Real-world use: An attacker learns from a press release that a company just moved to a new office, from Whois that it owns 203.0.113.0/24, and from a job ad that it runs IIS on Windows Server. He now has a phishing theme (office move), a scan range, and a likely exploit target.

Countermeasures and defense: Classify what the public may know; review press releases, job ads, and websites for technical leaks.

EXAM FOCUS:

- Asked as "Which of the following is network information obtained in footprinting?" Answer choices mix the three groups.
- Trap: Whois records and DNS records are network information, not system information. Email addresses and usernames are system information on this slide.

Memory trick: "O-N-S: Organization, Network, System" -> "One Nice Spy file".

3.4 Footprinting Methodology

What it is: A methodology is a step-by-step plan. The slide shows a tree of footprinting techniques divided into passive and active branches.

Analogy: A detective's checklist: check public records first, then interview neighbors, then follow the suspect.

```
FOOTPRINTING TECHNIQUES
|
+-- PASSIVE
|   +-- Search engines: Google hacking, GHDB, SHODAN
|   +-- Internet research services: people search,
|   |   financial and job sites, archive.org,
|   |   competitive intel and business profiles,
|   |   groups/forums/blogs, dark web tools
|   +-- Social networking sites: social media sites,
|   |   analyze social network graphs
|   +-- Whois: Whois lookup, IP geolocation lookup
|
+-- ACTIVE
    +-- DNS: DNS interrogation, reverse DNS lookup
    +-- Network and email: traceroute, track email
    +-- Social engineering: eavesdropping, shoulder
    |   surfing, dumpster diving, impersonation
    +-- Advanced tools and AI: Maltego, Recon-ng,
        FOCA, OSINT Framework, custom Python with AI
```

How it works:

1. Start with passive search engine work to find public files and devices.
2. Use internet research services to learn about people, money, jobs, and history.
3. Study social networking sites and the social graph (who knows whom).
4. Run Whois and geolocation lookups on domains and IPs.
5. Move to active DNS interrogation and reverse lookups.
6. Map the network path with traceroute and study email headers.
7. Use social engineering to fill gaps.
8. Automate and correlate everything with tools such as Maltego and Recon-ng, and with AI.

Key terms:

- **Social network graph:** a map of people as points and their relationships as lines. It shows who is connected to whom.
- **GHDB (Google Hacking Database):** a public list of ready-made Google search strings (dorks) that find sensitive data.

> **ADDED CONTEXT:** The official CEH courseware also lists "website footprinting" (web spiders, mirroring with HTTrack, Burp Suite, Website Informer, robots.txt) and "email footprinting" (eMailTrackerPro, Infoga). These were not shown in the screenshots but often appear in exam questions. They are covered in section 3.29 and section 4.

> **TRAP:** In this slide tree, the advanced tools and AI branch sits under "Active". Tools such as Maltego can do both passive and active work. If a question asks only "which tool", ignore the branch label and pick by function.

EXAM FOCUS:

- Asked as "Which technique is NOT passive?" Answer: DNS interrogation, traceroute, social engineering.
- Keywords: "dumpster diving", "shoulder surfing", "eavesdropping", "impersonation" -> social engineering branch.

Memory trick: Passive branch = "SIS-W" (Search, Internet research, Social networks, Whois). Active branch = "DNS-T" (DNS, Network and email, Social engineering, Tools/AI). Read it as "Sister Whois, then DNS Test".

3.5 Footprinting Using Advanced Google Hacking Techniques

What it is (simple words): Google hacking means using Google's advanced search operators to build complex queries. These queries pull out sensitive or hidden information that was never meant to be public. Attackers use it to find vulnerable targets.

- **Search operator:** a special keyword followed by a colon, such as site: or inurl:, that tells the search engine exactly where to look.
- **Google dork:** a ready-made query that uses operators to find something sensitive, for example exposed login pages or password files.

Analogy: A normal search is asking a librarian "anything about cars?". An operator search is asking "only red books, on shelf 4, with 'engine' in the title". You get exactly what you need.

How it works:

1. The attacker picks a target domain, for example example.com.
2. He combines operators: site:example.com restricts results to that domain.
3. He adds a filter: filetype:pdf, inurl:admin, or intitle:"index of".
4. Google returns only matching pages it has indexed, including pages the owner forgot about.
5. The attacker reviews results for login pages, intranet portals, technology names, and employee details.

Popular Google advanced search operators (from the slide):

Operator	Purpose (simple)	Example
cache:	Shows the copy of a page stored in Google cache	cache:www.example.com
link:	Lists pages that link to the given page	link:www.example.com
related:	Lists pages similar to the given page	related:www.example.com

Operator	Purpose (simple)	Example
info:	Shows what Google knows about a page	info:www.example.com
site:	Limits results to one domain	site:example.com
allintitle:	All keywords must be in the page title	allintitle:login portal
intitle:	One keyword must be in the title	intitle:login site:example.com
allinurl:	All keywords must be in the URL	allinurl:admin login
inurl:	One keyword must be in the URL	inurl:webcam
location:	Finds information for a specific location	location:dallas jobs

> **ADDED CONTEXT:** Other operators the exam expects you to know: filetype: (or ext:) limits results to a file type, for example filetype:pdf; intext: and allintext: search the page body; the minus sign excludes a word; quotes force an exact phrase. Google has retired cache: (2024) and link: and info: are limited today (verify), but the exam still tests their meaning.

More dork examples (ADDED CONTEXT, for reading practice):

```
site:example.com filetype:xls password
intitle:"index of" "parent directory" site:example.com
inurl:login site:example.com
site:example.com -www
filetype:sql "insert into" site:example.com
intitle:"webcamXP 5"
```

- Line 1: spreadsheets on the domain that mention "password".
- Line 2: open directory listings (a web server misconfiguration).
- Line 3: login pages on the domain.
- Line 4: pages on the domain that are not on www, so it reveals sub-domains.
- Line 5: leaked SQL dump files.
- Line 6: exposed webcam software pages.

> **ADDED CONTEXT:** The Google Hacking Database (GHDB) is hosted by Offensive Security on exploit-db.com. It groups dorks into categories such as Footholds, Files Containing Usernames, Sensitive Directories, Vulnerable Files, Error Messages, Files Containing Passwords, and Pages Containing Login Portals. The methodology slide names GHDB under search engine footprinting.

Real-world use: A tester runs site:client.com filetype:pdf and finds an old network diagram PDF. The diagram shows internal IP ranges and the firewall model. Result: the client removes the file and asks Google to drop it from the index.

Tools and commands used here: Google, GHDB, ChatGPT/ShellGPT (next topic).

AI angle: AI tools such as DorkGPT and DorkGenius (section 3.35) turn a plain-English request into a dork. Example prompt: "Write a Google dork that finds Excel files on example.com that contain the word budget."

Countermeasures and defense:

- Run the same dorks against your own domain and remove what you find.
- Use robots.txt and the noindex meta tag for pages that must not be indexed, but never rely on robots.txt for secrets (it is itself public).
- Ask search engines to remove cached copies; prevent caching (section 3.36).

EXAM FOCUS:

- How it is asked: "Which operator restricts results to a specific domain?" -> site:. "Which shows Google's stored copy of a page?" -> cache:. "Which finds pages similar to a target?" -> related:.
- Keywords: "in the title" -> intitle:/allintitle:. "in the URL" -> inurl:/allinurl:. "only PDF files" -> filetype:.
- Trap: allintitle: needs ALL words in the title; intitle: needs only the word right after it. Same rule for allinurl: vs inurl:.
- Look-alike: link: (pages that point TO the page) vs related: (pages SIMILAR to the page).

Memory trick: "C-L-R-I-S" for the first five operators on the slide: Cache, Link, Related, Info, Site -> "Clever Librarians Rarely Ignore Shelves". The "all" prefix means "all words must match".

3.6 Footprinting through Search Engines

What it is: Attackers use public search engines to extract information about a target: technology platforms, employee details, login pages, and intranet portals. This helps social engineering and other advanced attacks.

- **Intranet portal:** an internal company website meant only for employees. If it is indexed by a search engine, it is a leak.

Major search engines on the slide: Google, Bing, Yahoo, Ask, AOL, Baidu, DuckDuckGo.

Analogy: Different search engines are like different newspapers. Each one reports slightly different stories, so a good investigator reads several.

How it works:

1. Search the target name across several engines, because each indexes different pages.

2. Use advanced operators to build complex queries that filter and sort results.
3. Use search engines to find other public sources too. Example from the slide: search "top job portals" to find the main job sites, then search them for the target's job ads.

Real-world use: An attacker searches Baidu and Bing as well as Google and finds an old staff directory page that only Bing still indexes.

Tools and commands used here: Google, Bing, Yahoo, Ask, AOL, Baidu, DuckDuckGo.

Countermeasures and defense: Monitor all major engines, not just Google, for your domain.

EXAM FOCUS:

- Asked as "What can an attacker obtain through search engine footprinting?" -> technology platforms, employee details, login pages, intranet portals.
- Trap: DuckDuckGo does not track users, so attackers like it for searches that leave less trace. It is still a normal surface-web search engine, not a dark web tool.

Memory trick: "Good Bats Yell At All Big Ducks" -> Google, Bing, Yahoo, Ask, AOL, Baidu, DuckDuckGo.

3.7 Footprinting Using Advanced Google Hacking Techniques with AI

What it is: An attacker can use AI-powered ChatGPT, or another generative AI model, to create and run Google hacking commands from plain-English prompts. The demo uses ShellGPT on Parrot OS.

- **Generative AI:** AI that creates new content (text, code, images) from a prompt.
- **ShellGPT (sgpt):** a command-line tool that sends your prompt to a large language model (LLM) and returns shell commands or code. With --shell it offers to run the command for you.
- **Parrot OS:** a Linux distribution for security testing, similar to Kali Linux.

Prompt shown on the slide:

```
Use filetype search operator to obtain pdf files on the
target website eccouncil.org and store the result in the
recon1.txt file
```

How it works (as shown in the demo):

1. The tester types the prompt into ShellGPT with chat and shell modes.
2. ShellGPT asks the LLM and receives a shell command.
3. ShellGPT shows the command and asks: [E]xecute, [D]escribe, [A]bort.

4. The tester presses E. The command fetches Google results for site:eccouncil.org filetype:pdf, extracts the URLs, and writes them to recon1.txt.
5. The tester opens recon1.txt in the Pluma text editor and sees ten PDF links.

Command from the slide (best reading, the generated line is small):

```
sgpt --chat footprint --shell "Use filetype search operator \
to obtain pdf files on the target website eccouncil.org and \
store the result in the recon1.txt file"
```

The command that the AI generated is only partly readable [UNCLEAR on page 2]. It is a pipeline similar to this:

```
lynx --dump "http://www.google.com/search?q=\
site:eccouncil.org+filetype:pdf" | grep "url?q=" | \
cut -d "=" -f2 | cut -d "&" -f1 > recon1.txt
```

- lynx --dump: a text web browser that downloads the page and prints it as plain text.
- grep "url?q=": keeps only lines with Google result links.
- cut -d "=" -f2: splits each line at "=" and keeps the second field (the URL).
- cut -d "&" -f1: removes Google tracking parameters after "&".
- The redirect "> recon1.txt" saves the output to a file.

Sample output (recon1.txt as seen on the slide, shortened):

```
1 https://cert.eccouncil.org/images/doc/candidateagreement.pdf
2 https://aspen.eccouncil.org/Docs/Applications/
  ATC_Agreementv9.0.pdf
3 https://iclass.eccouncil.org/wp-content/uploads/2019/10/
  CSA-Essential-Concepts-Self-Study.pdf
4 https://aspen.eccouncil.org/Docs/UserGuides/
  AccessCourseware-UserGuide.pdf
6 https://cert.eccouncil.org/images/doc/CEH-Handbook-v6.pdf
9 https://cert.eccouncil.org/images/doc/Appeal-Form-v2.pdf
```

How to read it: each line is a public PDF on a sub-domain of the target. The sub-domain names (cert, aspen, iclass) are themselves useful: they reveal separate business units. The file names reveal document types (agreements, user guides, handbooks) that may carry metadata (see FOCA in section 3.34).

Real-world use: A tester saves an hour of manual dorking. The AI builds the command, and the tester checks and runs it.

Tools and commands used here: ChatGPT, ShellGPT (sgpt), lynx, grep, cut, Pluma.

AI angle:

- Attacker: writes dorks and scraping pipelines with no scripting skill.

- Defender: uses the same prompts on its own domain to find leaked documents first.
- Risk: always read the generated command before pressing E. LLMs can produce wrong or dangerous commands.

Countermeasures and defense: Remove sensitive PDFs from public servers; strip metadata before publishing.

EXAM FOCUS:

- Asked as "Which search operator returns only PDF files?" -> filetype:pdf.
- Asked as "In ShellGPT, which option makes it produce a shell command?" -> --shell (also -s).
- Trap: the AI does not "hack Google". It only automates the same operator search a human could do.

Memory trick: "sgpt = Shell GPT: Say it, Get the command, Press E."

3.8 Footprinting through SHODAN Search Engine

What it is (simple words): SHODAN is a search engine for internet-connected devices, not for web pages. It finds webcams, routers, servers, printers, industrial control systems, and IoT devices by reading the banners they send back.

- **Banner:** the short text a service sends when you connect, for example "HTTP/1.1 401 Unauthorized, Server: GoAhead-Webs". It often reveals the product and version.
- **IoT (Internet of Things):** everyday devices connected to the internet, such as cameras and smart plugs.

Analogy: Google reads the books in a library. SHODAN walks along every street and writes down what is printed on each building's door: the brand of lock, the alarm company, and whether the door is open.

How it works:

1. SHODAN's crawlers connect to IP addresses on common ports all over the internet.
2. They save each service banner with the IP, port, location, and organization.
3. A user searches by keyword (for example webcam), product, port, country, or organization.
4. SHODAN shows total results, top countries, top ports, top organizations, and the banner of each device.

What the slides show (https://www.shodan.io):

- Search 1: 204,560 total results. Top countries: Italy, Taiwan, Germany, United States, South Africa. Top ports include 5000, 8000, 8001. Many banners show "401"

(login required) responses from camera web interfaces. The search keyword is too small to read [UNCLEAR on page 2]; best reading: webcam.
- Search 2: 2,761,685 total results. Top countries: Japan, China, United States, Australia, Germany. Top port: 554, which is RTSP (Real Time Streaming Protocol, used by IP cameras for video). The keyword is too small to read [UNCLEAR on page 2]; best reading: a camera or RTSP related term.
- Each result shows the IP address, organization (ISP), country flag, and the raw banner. Buttons: View Report, Browse Images, View on Map.

Sample SHODAN queries (ADDED CONTEXT):

```
webcam country:IT
port:554 has_screenshot:true
apache city:"Dallas"
org:"Example Corp"
net:203.0.113.0/24
product:"MySQL" port:3306
hostname:example.com
```

Filter	Meaning	Example
country:	Two-letter country code	country:DE
city:	City name	city:"Tokyo"
port:	Open port on the device	port:23
org:	Organization or ISP owning the IP	org:"Example Corp"
net:	IP range in CIDR notation	net:198.51.100.0/24
hostname:	Host name contains a value	hostname:example.com
product:	Software or device product	product:"Apache httpd"
os:	Operating system	os:"Windows Server 2008"

Sample result (shortened, how to read):

```
151.21.10.67
WIND TRE                    <- organization (ISP)
Italy, Rome                 <- location
HTTP/1.0 401 Not Authorized  <- banner: login required
Server: Boa/0.94.14rc21      <- product and version
WWW-Authenticate: Basic      <- basic auth, weak
```

Each line tells the attacker something: who owns the IP, where it is, that it needs a login, which embedded web server (Boa) and which version, and that it uses basic authentication. The version can be matched against known vulnerabilities.

Real-world use: A security team at a retail chain searches SHODAN for net: ranges they own. They find a forgotten DVR on port 554 with default credentials and take it offline.

Tools and commands used here: SHODAN website, SHODAN CLI (shodan search, shodan host - ADDED CONTEXT).

> **ADDED CONTEXT:** Censys (search.censys.io) and ZoomEye are SHODAN alternatives that also index devices and certificates. The exam may place them next to SHODAN as distractors or as correct alternatives.

AI angle: An attacker can ask an LLM to "write a SHODAN query to find exposed RTSP cameras in a given country". Defenders use AI to triage hundreds of SHODAN hits on their own ranges.

Countermeasures and defense:

- Do not expose admin interfaces, cameras, or ICS devices directly to the internet; use a VPN.
- Change default credentials and remove version info from banners.
- Search SHODAN for your own IP ranges regularly.

EXAM FOCUS:

- Asked as "Which search engine finds internet-connected devices such as webcams, routers, and SCADA systems?" -> SHODAN.
- Keywords: "IoT", "banner", "webcam", "ICS/SCADA", "connected devices" -> SHODAN.
- Trap: SHODAN does not scan your target when you search; it shows data it already collected. Using it is passive for the user.
- Look-alike: SHODAN (devices) vs Google (web pages) vs Netcraft (sites, sub-domains, hosting OS).

Memory trick: "SHODAN = Shows Hosts On Devices Across the Net."

3.9 Natural-Language Search vs Operator Search (Google Webcam Demo)

What it is: The instructor typed a plain-English request into Google: "Find for me a list of websites that have the term webcam in the url". Google showed general results (EarthCam, "People also ask" boxes). Then he used the operator form inurl:webcam, and Google showed only pages with "webcam" in the URL (Amazon webcam product pages, TechRadar reviews, neave.com Webcam Toy).

Analogy: Asking a shop assistant "something warm to wear" gets you many suggestions. Asking for "wool sweater, size M, blue" gets you exactly one shelf.

How it works:

1. A natural-language query is read for meaning. Results are broad and ranked by popularity.

2. An operator query is a strict filter. Only pages that match the rule appear.
3. For recon, the strict filter is better: it removes noise and finds exactly the pages that match a pattern (for example camera admin pages).

Real-world use: A tester who needs camera pages types inurl:webcam or intitle:"webcamXP" rather than a sentence. He gets device pages, not shopping pages.

Tools and commands used here: Google search, inurl: operator.

AI angle: Modern search engines and AI assistants translate plain language into operators. A beginner can type a sentence, but should learn the operator to control results exactly.

EXAM FOCUS: "Which query finds pages whose URL contains webcam?" -> inurl:webcam. Do not pick intitle:webcam (title, not URL) or site:webcam (site: needs a domain).

Memory trick: "IN-URL = IN the address bar."

3.10 Finding a Company's Top-Level Domains (TLDs) and Sub-domains

What it is (simple words): A company's external website lives on a domain, such as microsoft.com. Sub-domains such as support.microsoft.com or careers.microsoft.com sit under it. Finding them reveals departments, business units, and forgotten servers.

- **TLD (top-level domain):** the last part of a domain name, such as .com, .org, .uk. A company may own example.com, example.co.uk, and example.net.
- **Sub-domain:** a name added before the main domain, such as vpn.example.com.

Analogy: The main domain is the front door of a big building. Sub-domains are side doors for staff, deliveries, and old storage rooms. Side doors are often less guarded.

How it works:

1. Search the target company's external URL in Google and Bing.
2. Find sub-domains by trial and error (guess common names such as mail, vpn, dev, test) or with a service.
3. Use Netcraft (https://www.netcraft.com) to list hostnames matching a pattern, for example *.microsoft.com.
4. Use DNSdumpster (https://dnsdumpster.com) to discover hosts related to a domain and their IPs.
5. Record each sub-domain with its IP, netblock owner, and OS for later scanning.

What the slides show:

- Netcraft "Hostnames matching *.microsoft.com", first 500 results. Columns: Rank, Site, First seen, Netblock (Microsoft Corporation, Akamai International BV, Akamai Technologies), OS (Windows Server 2008, Linux, unknown).
- DNSdumpster results for eccouncil.org: a list of sub-domains, each with an IP address and hosting details.

Real-world use: A tester finds dev-portal.client.com on DNSdumpster. It runs an old Windows Server version shown by Netcraft. The client did not know the server still existed.

Tools and commands used here: Google, Bing, Netcraft, DNSdumpster. Related: Sublist3r, subfinder, dig (sections 3.11 and 3.34).

> **ADDED CONTEXT:** Certificate transparency logs (crt.sh) list every public TLS certificate issued for a domain. Searching %.example.com on crt.sh is a fast passive way to find sub-domains.

Countermeasures and defense:

- Keep an inventory of all sub-domains and shut down unused ones.
- Avoid revealing internal names in public DNS (use split DNS, section 3.38).
- Check Netcraft and DNSdumpster for your own domain.

EXAM FOCUS:

- Asked as "Which tool lists sub-domains and the OS of a target's web servers?" -> Netcraft. "Which online tool discovers hosts related to a domain?" -> DNSdumpster.
- Keywords: "sub-domains reveal departments and business units" -> sub-domain footprinting.
- Trap: trial and error is a valid method listed on the slide, but it is slow; a tool or service is the best answer for "most efficient".

Memory trick: "Netcraft crafts the Net map; DNSdumpster dumps the DNS hosts."

3.11 Finding TLDs and Sub-domains with AI

What it is: ChatGPT or another generative AI can generate and run sub-domain discovery commands from prompts.

Prompts shown on the slide:

```
1. Discover all the subdomains of 'google.com' using dig
   command
2. Use Sublist3r to gather a list of subdomains of the
   target organization eccouncil
```

- **dig (Domain Information Groper):** a Linux command-line tool that queries DNS servers for records.
- **Sublist3r:** a Python tool that enumerates sub-domains using OSINT sources: search engines (Google, Yahoo, Bing, Baidu, Ask) and services (Netcraft, VirusTotal, ThreatCrowd, DNSdumpster, ReverseDNS). It can also brute-force names.

How it works:

1. The tester runs sgpt --chat footprint --shell with the prompt.
2. For prompt 1, the AI produces dig commands. dig alone cannot list every sub-domain; the AI usually tries a zone transfer (dig axfr) or loops over a word list of common names.
3. For prompt 2, the AI produces a Sublist3r command such as sublist3r -d eccouncil.org.
4. The tester executes with E and reads the list of sub-domains.

Commands (likely forms, the slide text is small [UNCLEAR on page 4]):

```
sgpt --chat footprint --shell "Use Sublist3r to gather a \
list of subdomains of the target organization eccouncil"
sublist3r -d eccouncil.org
dig google.com ANY
dig axfr @ns1.google.com google.com
```

Real-world use: A junior tester who does not remember Sublist3r flags asks the AI and gets a working command in seconds.

AI angle: AI lowers the skill barrier. Defenders should expect even unskilled attackers to enumerate sub-domains fully.

Countermeasures and defense: Restrict zone transfers to authorized secondary servers only; then dig axfr returns "Transfer failed".

EXAM FOCUS:

- Asked as "Which Sublist3r option sets the target domain?" -> -d. "Which enables brute force?" -> -b.
- Trap: dig ANY often returns little today because many servers refuse ANY queries (RFC 8482). A full list needs AXFR or brute force.

Memory trick: "Sublist3r = Sub-domain LISTer."

3.12 Extracting Website Information from archive.org (Wayback Machine and Photon)

What it is (simple words): The Internet Archive's Wayback Machine (https://archive.org) stores old copies of websites. Anyone can visit an archived version of a site as it looked on a past date.

Analogy: It is a photo album of a website. Even if the company repainted the house, the old photos still show where the back door used to be.

How it works:

1. Open web.archive.org and type the target URL, for example https://www.microsoft.com.
2. The timeline shows how many snapshots exist. The slide shows microsoft.com saved 297,283 times between October 20, 1996 and March 7, 2024 (small text, verify).
3. Pick a year, then a highlighted date on the calendar (circles show snapshot days).
4. The archived page opens. The demo shows an old Microsoft Copilot page.
5. The attacker looks for old staff names, phone numbers, removed pages, old login portals, and old technology.

Photon: Attackers can use Photon to retrieve archived URLs of the target website from archive.org. Photon is a fast Python web crawler that extracts URLs, emails, files, and secret keys. Its --wayback option uses archive.org URLs as starting points (seeds).

```
python3 photon.py -u https://www.example.com --wayback
python3 photon.py -u https://www.example.com -l 3 -t 10 \
  -o example_out
```

Real-world use: A company removed its employee directory page in 2022. An attacker opens the 2021 snapshot and gets 300 names and email formats for a phishing campaign.

Tools and commands used here: Wayback Machine, Photon.

Countermeasures and defense: Never publish sensitive data in the first place; once archived, it is hard to remove. Site owners can request exclusion from the Internet Archive.

EXAM FOCUS:

- Asked as "Which resource lets an attacker view a website's content as it was in the past?" -> archive.org / Wayback Machine.
- Asked as "Which tool retrieves archived URLs of a target from archive.org?" -> Photon.
- Trap: Google cache: shows only the latest cached copy. The Wayback Machine shows many dated snapshots over years.

Memory trick: "Wayback = Way back in time. Photon = flash of light into the old archive."

3.13 Footprinting through People Search Services and Job Sites

What it is: People search services and job sites give a lot of information about people and about a company's IT setup.

- **People search services:** Spokeo, Intelius, and pipl. They provide information about a person or organization: location, emails, websites, blogs, contacts, important dates, and address.
- **Job sites:** Dice, LinkedIn, and Glassdoor. Job ads reveal details of the company's infrastructure and help attackers identify vulnerabilities in the IT environment.

Analogy: A job ad saying "must know Cisco ASA 5500 and Windows Server 2012" is like a bank posting "we need a guard who knows our old Model-X vault".

How it works:

1. Search the person's name on Spokeo. The demo searched "John Furner" and got many matches with age, cities, and relatives.
2. Search the company on job sites. The demo shows a Glassdoor ad for a "Junior Network Administrator / Assistant" in Dallas, Texas.
3. Read the requirements: server OS versions, virtualization, firewalls, network gear, cloud platforms.
4. Map the technology list to known weaknesses.

Real-world use: An attacker sees a job ad that lists "VMware ESXi 6.5" and "SonicWall". He looks up public exploits for those versions before scanning.

Tools used here: Spokeo, Intelius, pipl, Dice, LinkedIn, Glassdoor.

Countermeasures and defense: Write job ads with general skills ("firewall experience") instead of exact products and versions. Opt out of people search sites where possible.

EXAM FOCUS:

- "Which source reveals a target's infrastructure details such as OS and hardware?" -> job sites.
- "Which services give a person's address, contacts, and important dates?" -> people search (Spokeo, Intelius, pipl).
- Trap: LinkedIn appears both as a job site and as a social network. Pick by purpose: hiring details = job site.

Memory trick: "SIP for people (Spokeo, Intelius, pipl). DLG for jobs (Dice, LinkedIn, Glassdoor)."

3.14 Dark Web Footprinting

What it is (simple words): The dark web, or darknet, is a deeper layer of the internet. It lets anyone browse anonymously without being traced. Attackers search it for confidential information about a target, such as leaked credentials, stolen databases, or insiders selling access.

- **Surface web:** pages that normal search engines index.
- **Deep web:** pages not indexed, such as online banking pages and private databases (ADDED CONTEXT).
- **Dark web:** hidden services reachable only with special software such as Tor. Addresses end in .onion.
- **Tor (The Onion Router):** a network that sends traffic through several volunteer servers (relays), wrapping it in layers of encryption like an onion.

Analogy: The surface web is the high street. The deep web is the back offices behind locked doors. The dark web is an unmarked basement market that you can only enter through a secret tunnel, wearing a mask.

How it works:

1. The attacker installs Tor Browser (https://www.torproject.org).
2. Tor Browser acts as a default VPN for the user. It bounces the user's IP address through several servers before reaching the website, so the site cannot see the real IP.
3. The attacker uses dark web search engines and advanced search parameters to refine searches.
4. The demo uses DuckDuckGo (the default search engine in Tor Browser) with an advanced parameter: "Elon Musk" site:facebook.com, to find a personal profile.
5. A second demo searches "hackers for hire" and finds freelance hacking services.
6. ExoneraTor is also named as a dark web searching tool.

> **ADDED CONTEXT:** ExoneraTor is run by the Tor Project. It tells you whether a given IP address was used as a Tor relay on a given date. Investigators use it to check if traffic from an IP came from the Tor network. Other dark web search tools in the CEH courseware include OnionLand Search, The Hidden Wiki, and FakeID (verify).

Real-world use: A threat intelligence analyst searches dark web forums for her company's name. She finds a post selling VPN logins of two employees. The company resets the accounts before attackers use them.

Tools used here: Tor Browser, ExoneraTor, DuckDuckGo with advanced parameters.

Countermeasures and defense: Monitor the dark web for company names, domains, and leaked credentials; enforce MFA so leaked passwords alone are useless.

EXAM FOCUS:

- "Which tool lets an attacker browse the dark web anonymously?" -> Tor Browser.
- "Which tool checks whether an IP was a Tor relay?" -> ExoneraTor (added context).
- Trap: the deep web is not the same as the dark web. Deep = not indexed. Dark = hidden and needs Tor.

Memory trick: "Tor = Tunnel Of Relays."

3.15 Competitive Intelligence Gathering

What it is (simple words): Competitive intelligence gathering is the process of identifying, gathering, analyzing, verifying, and using information about competitors from resources such as the internet. It is non-interfering and subtle: the target does not notice it.

Analogy: A coffee shop owner visits the rival shop as a normal customer, reads its menu, and checks its prices online. Nothing is stolen and nobody is disturbed.

How it works:

1. Identify what you need to know (products, plans, partners, finances).
2. Gather it from the sources below.
3. Analyze and verify it against other sources.
4. Use it for decisions; an attacker uses it for targeting and pretexts.

Sources of competitive intelligence (10, from the slide):

1. Company websites and employment ads
2. Search engines, internet, and online databases
3. Press releases and annual reports
4. Trade journals, conferences, and newspapers
5. Patents and trademarks
6. Social engineering employees
7. Product catalogs and retail outlets
8. Analyst and regulatory reports
9. Customer and vendor interviews
10. Agents, distributors, and suppliers

> **ADDED CONTEXT:** The CEH courseware also groups competitive intelligence by questions: "When did this company begin? How did it develop?" (EDGAR, D&B Hoovers, LexisNexis), "What are the company's plans?" (MarketWatch, The Wall Street Transcript), and "What do experts think?" (SimilarWeb, SERPstat). Verify the exact tool lists.

Real-world use: An attacker reads a target's annual report and learns it uses a named logistics partner. He then sends phishing emails that pretend to come from that partner.

EXAM FOCUS:

- Keywords: "non-interfering", "subtle", "legal", "about competitors" -> competitive intelligence.
- The five verbs in order: identifying, gathering, analyzing, verifying, using.
- Trap: "social engineering employees" is in the source list even though it is active. Do not assume all ten sources are passive.

Memory trick: Verbs: "I Got A Very Useful tip" -> Identify, Gather, Analyze, Verify, Use.

3.16 Other Techniques for Footprinting through Internet Research Services

What it is: The slide is a table of seven more research techniques. Each has a purpose, the information it gives, and the tools used. Long content is listed as mini-blocks.

1. Finding the geographical location of the target

- Description: obtain the physical location of the target.
- Information: entrances to buildings, security cameras, gates, places to hide, weak spots in perimeter fences.
- Tools: Google Earth, Google Maps, Wikimapia.

2. Gathering information from financial services

- Description: search for financial data such as stock quotes and charts, financial news, and portfolios.
- Information: market value of the company's shares, company profile, competitor details.
- Tools: Google Finance, MSN Money, Yahoo! Finance.

3. Gathering information from business profile sites

- Description: retrieve business information about companies in a particular region.
- Information: location, addresses, contact information, employee database of the target.
- Tools: opencorporates, Crunchbase, corporationwiki.

4. Monitoring targets using alerts

- Description: obtain up-to-date information about the target, usually via email or SMS.
- Information: mentions of the organization's name, member names, website, or any of its people or projects.
- Tools: Google Alerts, X Alerts (formerly Twitter alerts), Giga Alerts.

5. Tracking the online reputation of the target

- Description: monitor a company's reputation on the internet.
- Information: search engine ranking, email notifications when the company is mentioned online, social news about the company.
- Tools: Mention, ReviewPush, Reputology.

6. Gathering information from groups, forums, and blogs

- Description: join the target organization's employee groups where they share personal and company information.
- Information: public network information, system information, personal information.
- Tools: Google Groups, LinkedIn Groups.

7. Gathering information from public source-code repositories

- Description: identify information about the developers and the technologies used.
- Information: configuration files, private SSH and SSL keys, source-code files, dynamic libraries, and software tools developed by contributors.

- Tools: Recon-ng.

- **SSH key:** a secret file that logs a user into a server without a password. A leaked private key = a leaked login.

- **SSL/TLS private key:** the secret part of a website certificate. If leaked, an attacker can impersonate the site or decrypt traffic.
- **Dynamic library:** shared code (.dll on Windows, .so on Linux) loaded by programs at run time.

Real-world use: A tester searches GitHub for the client's domain and finds a developer's repo with a config file holding a database password.

Countermeasures and defense: Scan your own repos for secrets before pushing (git-secrets, truffleHog, gitleaks - ADDED CONTEXT); blur building photos where possible; train staff about forums.

EXAM FOCUS:

- Match the tool to the row: Google Earth = location; Yahoo! Finance = financial; Crunchbase = business profile; Google Alerts = alerts; ReviewPush = reputation; Google Groups = forums; Recon-ng = source-code repos.
- Trap: Google Alerts sends updates automatically; it does not search on demand.

Memory trick: "Lazy Foxes Bark At Red Gray Rabbits" -> Location, Financial, Business profile, Alerts, Reputation, Groups, Repositories.

3.17 Harvesting Email Lists (theHarvester, Email Spider) with AI

What it is (simple words): Attackers use automated tools such as theHarvester and Email Spider to collect publicly available email addresses of the target organization. The list helps social engineering (phishing) and brute-force attacks (guessing passwords for each address).

- **theHarvester:** an open-source Python OSINT tool by Christian Martorella (Edge-Security). It gathers emails, sub-domains, hosts, IPs, and URLs from public sources such as search engines and certificate logs.
- **Email Spider:** a tool that crawls websites and extracts email addresses.
- **Brute-force attack:** trying many passwords for a username until one works.

Analogy: theHarvester is a farmer with a big net, collecting every email address lying around on public fields.

How it works:

1. Choose the domain and the data source (search engine or service).
2. theHarvester queries that source for pages that mention the domain.
3. It extracts strings that look like emails and host names.
4. It prints the emails and hosts found and can save them to a file.

Command from the slide:

```
theHarvester -d microsoft.com -l 200 -b baidu
```

- -d microsoft.com: the target domain.
- -l 200: limit the number of results to 200.
- -b baidu: use Baidu as the data source.

Sample output (as seen on the slide, shortened):

```
* theHarvester 4.x.x (version small, verify)
* Coded by Christian Martorella
* Edge-Security Research
[*] Target: microsoft.com
        Searching Baidu.
[*] No IPs found.
[*] Emails found: 1
----------------------
edge_e...@microsoft.com
[*] Hosts found: 5
---------------------
windowsupdate.microsoft.com
docs.microsoft.com
technet.microsoft.com
testconnectivity.microsoft.com
```

How to read it: "Target" confirms the domain. "Searching Baidu" confirms the source. "No IPs found" means the source returned no addresses. "Emails found" lists harvested emails. "Hosts found" lists sub-domains mentioned on indexed pages.

AI prompt on the slide:

```
Use theHarvester to gather email accounts associated with
microsoft.com, limiting results to 200, and leveraging
'baidu' as a data source
```

In the AI demo (sgpt --chat ... --shell), the AI produced the same theHarvester command and found more emails (about 9) and hosts (about 15) [exact counts UNCLEAR on page 7].

Real-world use: A red team harvests 120 addresses, works out the format first.last@company.com, and builds a phishing target list.

Countermeasures and defense: Use role addresses (info@, sales@) on public pages; obfuscate emails on websites; enforce MFA and account lockout against brute force.

EXAM FOCUS:

- "Which tool gathers emails and sub-domains from public sources?" -> theHarvester.
- Flag recall: -d domain, -l limit, -b source.
- Trap: theHarvester's -b means "data source", not "brute force" (in Sublist3r -b means brute force).

Memory trick: "theHarvester: Domain, Limit, Basket (source)".

3.18 Analyzing Target Social Media Presence (BuzzSumo, Google Trends, Hashatit)

What it is: Attackers track social media sites with tools such as BuzzSumo, Google Trends, and Hashatit. They discover the most shared content using hashtags or keywords, and they track accounts, URLs, and email addresses. They use this for phishing, social engineering, and other attacks.

- **BuzzSumo:** an advanced social search engine that finds the most shared content for a topic, author, or domain. The demo used its Content Analyzer on microsoft.com and saw engagement counts per article.
- **Google Trends:** shows how popular a search term is over time and by region.
- **Hashatit:** a hashtag search engine across social networks.
- **Hashtag:** a word with # in front, used to tag posts, for example #ITjobs.

Analogy: It is like finding out which posters on the town notice board get the most attention, so you can put your fake poster right next to them.

How it works:

1. Enter a keyword, hashtag, or domain.
2. The tool shows top-shared posts, authors, and engagement numbers.
3. The attacker learns what topics employees care about and which accounts they trust.
4. He crafts a phishing message on a hot topic, so the victim is more likely to click.

Real-world use: BuzzSumo shows that a company's staff share a charity run article. The attacker sends a fake "charity run registration" link.

Tools used here: BuzzSumo (https://buzzsumo.com), Google Trends, Hashatit.

Countermeasures and defense: Train staff that trending topics are common phishing lures; verify links before clicking.

EXAM FOCUS: "Which tool finds the most shared content for a topic, author, or domain?" -> BuzzSumo. Trap: BuzzSumo analyzes content popularity; Sherlock finds usernames.

Memory trick: "BuzzSumo = the BUZZ (most shared) champion (Sumo)."

3.19 Tools for Footprinting through Social Networking Sites (Sherlock, Social Searcher)

What it is:

- **Sherlock:** a command-line tool that searches a vast number of social networking sites (400+) for a target username and lists where the account exists.
- **Social Searcher:** a website (https://www.social-searcher.com) that searches content in social networks in real time and gives deep analytics data (mentions, sentiment, users, popular posts).

Analogy: Sherlock is a detective knocking on 400 doors asking "does Alice live here?" and writing down every "yes".

How it works (Sherlock):

1. Sherlock holds a list of sites and their profile URL patterns, for example https://www.site.com/USERNAME.
2. It puts the username into each pattern and sends a request.
3. If the page exists (or the response matches a known pattern), it prints [+] with the URL.
4. Results are saved to USERNAME.txt by default.

Command from the slide:

```
sudo su
cd sherlock
sherlock "Elon Musk"
```

Sample output (from the slide, shortened):

```
[*] Checking username Elon Musk on:
[+] Archive.org: https://archive.org/details/@Elon Musk
[+] CGTrader: https://www.cgtrader.com/Elon Musk
[+] Codeforces: https://codeforces.com/profile/Elon Musk
[+] HackerEarth: https://hackerearth.com/@Elon Musk
[+] Instructables: https://www.instructables.com/member/
    Elon Musk
[+] Slides: https://slides.com/Elon Musk
```

How to read it: [*] is a status line. Each [+] line is a site where a matching profile URL answered. Some hits are false positives; always open the link to confirm. A name with a space is unusual as a username, so many results here need checking.

Real-world use: A tester finds the target admin's username "jsmith_ops" on GitHub, Reddit, and a gaming forum. The forum post mentions his company VPN brand.

Countermeasures and defense: Use different usernames for work and personal accounts; keep profiles private.

EXAM FOCUS: "Which tool searches many social networking sites for a username?" -> Sherlock. "Which tool searches social network content in real time with analytics?" -> Social Searcher.

Memory trick: "Sherlock hunts the NAME; Social Searcher reads the POSTS."

3.20 Footprinting through Social Networking Sites with AI

What it is: ChatGPT or another generative AI can run Sherlock for you from a prompt and save the result.

Prompt on the slide:

```
Use Sherlock to gather personal information about Sundar
Pichai and save the result in recon2.txt
```

How it works:

1. The tester runs sgpt --chat footprint --shell with the prompt.
2. The AI builds a Sherlock command for the username SundarPichai and redirects output to recon2.txt.
3. The tester executes with E. Sherlock prints [+] hits.
4. recon2.txt lists URLs such as about.me, academia.edu, aminoapps.com, behance.net, blogger (blogspot), cgtrader, cnet, codecademy, codeforces, codesrank, disqus, duolingo, fiverr, freelancer, giphy.

Likely generated command (small text, verify):

```
sherlock SundarPichai > recon2.txt
sherlock SundarPichai --output recon2.txt
```

- The redirect "> recon2.txt" is a shell redirect; it saves everything printed.
- --output (or -o): Sherlock's own option to save results for a single username.

AI angle: AI turns "find this person everywhere" into one command. Defenders can use the same to audit executives' exposure.

EXAM FOCUS: Expect "Which tool would the AI call to find a person's accounts across social sites?" -> Sherlock.

Memory trick: "Ask the AI, it calls Sherlock."

3.21 Whois Lookup

The screenshots show "Whois Lookup (Cont'd)" (slide 30) before "Whois Lookup" (slide 29). Both are merged here.

What it is (simple words): Whois is a query and response protocol that looks up who registered a domain name or an IP address block. Whois databases are maintained by Regional Internet Registries (RIRs) and contain personal information of domain owners.

- **Regional Internet Registry (RIR):** an organization that manages IP address and AS number allocation for one region of the world.
- **Registrar:** a company that sells domain names (for example GoDaddy). The registrar also stores Whois data for domains.
- **NetRange:** the range of IP addresses assigned to an organization, for example 162.241.0.0 - 162.241.255.255.

Analogy: Whois is the land registry. Look up a house address and you see the owner's name, when they bought it, when the lease expires, and who manages the building.

What a Whois query returns (from the slide):

1. Domain name details
2. Contact details of domain owners
3. Domain name servers
4. NetRange
5. When a domain was created
6. Expiry records
7. Last updated record

How the information helps an attacker:

- Gather personal information that assists in social engineering (names, phones, emails of admins).
- Create a map of the target organization's network (name servers, IP ranges).
- Obtain internal details of the target network.

The five RIRs:

RIR	Region
ARIN	United States, Canada, parts of the Caribbean
AFRINIC	Africa
RIPE NCC	Europe, Middle East, Central Asia
LACNIC	Latin America and parts of the Caribbean
APNIC	Asia Pacific

How it works:

1. The user enters a domain (certifiedhacker.com) in a Whois tool or website.
2. The tool asks the registry and registrar Whois servers (TCP port 43).
3. It returns the record: registrar, dates, name servers, registrant contact (or privacy proxy).
4. For an IP address, the tool asks the right RIR and returns the NetRange and owner.

What slide 30 shows: A Whois record for certifiedhacker.com from https://whois.domaintools.com (registrant organization, registrar, dates, name servers ns1/ns2.bluehost.com, IP location, status). A second Windows Whois tool with a green interface is shown; its name is too small to read [UNCLEAR on page 9]; best reading: a desktop Whois client such as SmartWhois (tamos.com) or Batch IP Converter (verify).

Command (ADDED CONTEXT):

```
whois certifiedhacker.com
whois 162.241.216.11
whois -h whois.arin.net 162.241.216.11
```

Sample output (shortened, how to read):

```
Domain Name: CERTIFIEDHACKER.COM
Registrar: Network Solutions, LLC        <- who sold it
Creation Date: 2002-07-30                <- age of domain
Registry Expiry Date: 2026-07-30         <- renewal date
Updated Date: 2024-05-01                 <- last change
Name Server: NS1.BLUEHOST.COM            <- DNS host
Name Server: NS2.BLUEHOST.COM
Registrant Organization: (privacy)       <- owner or proxy
```

The dates and registrar in this sample are illustrative, not taken from the slide. An expiry date that is close can tempt an attacker to try domain hijacking. Name servers show the DNS hosting provider. A privacy proxy in the registrant field means the owner hid personal details.

Real-world use: A tester runs whois on the client's domain and finds the IT manager's direct phone number and personal email. He reports it, and the client turns on Whois privacy.

Tools used here: whois.domaintools.com, desktop Whois tools [UNCLEAR], whois command, RIR websites.

Countermeasures and defense: Opt for privacy services on the Whois database; sanitize registrar details to hide direct contact details (section 3.38); use role contacts.

EXAM FOCUS:

- "Which organization manages IP addresses in Europe?" -> RIPE NCC. "Africa?" -> AFRINIC. "Asia Pacific?" -> APNIC.
- "What does Whois NOT return?" Distractors such as "open ports" or "OS version" are not in Whois.
- Trap: Whois is listed under passive footprinting because you query public registry servers, not the target.

Memory trick: RIRs: "All Africans Run Like Antelopes" -> ARIN, AFRINIC, RIPE NCC, LACNIC, APNIC. Location hint: the first letters A-AF-R-LA-AP = America, Africa, Rest of Europe, Latin America, Asia Pacific.

3.22 Extracting DNS Information

What it is (simple words): DNS (Domain Name System) turns names into IP addresses. DNS records give important information about the location and types of servers. Attackers gather DNS information to determine key hosts in the network and to perform social engineering attacks.

- **DNS record (resource record):** one entry in a DNS zone, such as "www -> 203.0.113.10".
- **Zone:** all DNS records for one domain, stored on its authoritative name servers.
- **DNS interrogation:** asking DNS servers for these records.

Analogy: DNS is a phone book. Each record type is a different column: home number (A), office mail room (MX), who publishes the book (NS, SOA), nicknames (CNAME), reverse lookup from number to name (PTR).

DNS record types (from the slide):

Record type	Description (simple)
A	Points to a host's IP address
MX	Points to the domain's mail server
NS	Points to the host's name server
CNAME	Canonical name; allows aliases for a host
SOA	Indicates the authority for the domain
SRV	Service records (which host offers a service)
PTR	Maps an IP address to a hostname
RP	Responsible person
HINFO	Host info; includes CPU type and OS
TXT	Unstructured text records

> **ADDED CONTEXT:** AAAA points to an IPv6 address. TXT records often hold SPF (which servers may send mail for the domain), DKIM keys, and domain verification tokens for cloud services, which reveal the vendors a company uses. HINFO is rarely published today, but it is a big leak when present.

How it works:

1. The attacker queries DNS servers with DNS interrogation tools.
2. The slide names SecurityTrails, DNSChecker, and others. The tool names are small [UNCLEAR on page 9]; best reading: "SecurityTrails, Fierce, DNSChecker, and zdns" (verify).
3. The tools return the record structure: A, MX, NS, TXT, SOA records and history.
4. The attacker lists mail servers, name servers, and key hosts as targets.

- **SecurityTrails (https://securitytrails.com):** a website with current and historical DNS data for a domain.
- **DNSChecker:** a website that checks DNS records from many locations.
- **Fierce (ADDED CONTEXT):** a Perl tool that finds non-contiguous IP space and hostnames, and tries zone transfers.

Commands (ADDED CONTEXT, standard DNS tools):

```
dig certifiedhacker.com A
dig certifiedhacker.com MX +short
dig certifiedhacker.com NS
nslookup -type=mx certifiedhacker.com
host -t txt certifiedhacker.com
dig axfr @ns1.example.com example.com
```

Zone transfer (ADDED CONTEXT): A zone transfer (AXFR) copies the whole zone from a primary DNS server to a secondary one. If the server allows anyone to request it, an attacker gets every host name at once. This is why the countermeasure "restrict zone transfer to authorized servers" exists.

```
nslookup
> server ns1.example.com
> set type=any
> ls -d example.com
```

The nslookup "ls -d" command is the classic Windows way to request a zone transfer (older versions; verify on modern Windows).

Real-world use: A tester finds an MX record for mail.client.com and a TXT SPF record that includes a cloud mail provider. Now he knows where to send phishing tests and which vendor to impersonate.

Countermeasures and defense: Restrict zone transfers; use split DNS; do not publish HINFO or internal names; keep only needed records.

EXAM FOCUS:

- Record recall: "Which record identifies the mail server?" -> MX. "Maps IP to hostname?" -> PTR. "Gives CPU and OS?" -> HINFO. "Start of authority?" -> SOA. "Alias?" -> CNAME. "Responsible person?" -> RP.
- Trap: NS points to the name server; SOA holds the primary name server, admin email, serial number, and timers for the zone.

Memory trick: "A = Address, MX = Mail eXchange, NS = Name Server, PTR = PoinTeR back, SOA = Start Of Authority, HINFO = Hardware INFO."

3.23 Finding IP Geolocation Information

What it is: IP geolocation maps an IP address to a physical place and network details. It helps identify country, region/state, city, ZIP/postal code, time zone, connection speed, ISP (hosting company), domain name, IDD country code, area code, mobile carrier, and elevation.

- **ISP:** Internet Service Provider, the company that provides the internet connection or hosting.
- **IDD country code:** International Direct Dialing code, for example +1 for USA.

Analogy: It is like using a postal code to guess which neighborhood a letter came from. It is a good guess, not a precise house number.

How it works:

1. Enter an IP address (or domain) in an IP geolocation lookup tool.
2. The tool checks databases that map IP ranges to locations and ISPs.
3. It returns the fields above.
4. Attackers use the results to launch social engineering attacks such as spamming and phishing that look local and believable.

Tools: IP2Location (https://www.ip2location.com) and IP Location Finder.

Real-world use: An attacker finds the target's office IP is in Dallas with a given ISP. He writes a phishing email about "Dallas office internet maintenance by [ISP]".

Countermeasures and defense: Hosting public services behind a CDN hides the real hosting location; train staff about locally themed phishing.

EXAM FOCUS: "Which tool reveals the ISP, time zone, and city of an IP?" -> IP2Location. Trap: geolocation is approximate; it cannot find an exact street address for most IPs.

Memory trick: "IP2Location = IP to Location."

3.24 DNS Lookup with AI (DNSRecon)

What it is: ChatGPT or another generative AI can install and run DNSRecon to perform DNS enumeration on a target.

- **DNSRecon:** a Python DNS enumeration tool. It checks NS, SOA, MX, A, AAAA, TXT, SPF, and SRV records, tries zone transfers, brute-forces sub-domains, and does reverse lookups on IP ranges.
- **DNS enumeration:** collecting as many DNS records about a domain as possible.

Prompt on the slide:

```
Install and use DNSRecon to perform DNS enumeration on the
target domain www.certifiedhacker.com
```

How it works (from the demo):

1. sgpt --chat domain --shell "Install and use DNSRecon to perform DNS enumeration on the target domain www.certifiedhacker.com".
2. The AI generates an install plus run command. The tester presses E.
3. apt updates package lists (lines "Hit:1 https://deb.parrot.sh/parrot lory InRelease ... Reading package lists... Done").
4. DNSRecon runs a standard enumeration and prints the records.

Likely generated command (verify):

```
sudo apt install dnsrecon -y && \
dnsrecon -d certifiedhacker.com
```

Sample output (as seen on the slide, shortened):

```
[*] std: Performing General Enumeration against:
    certifiedhacker.com...
[-] DNSSEC is not configured for certifiedhacker.com
[*]  SOA ns1.bluehost.com 162.159.24.80
[*]  NS ns1.bluehost.com 162.159.24.80
[*]  Bind Version for 162.159.24.80 "2024.2.2"
[*]  NS ns2.bluehost.com 162.159.25.175
[*]  MX mail.certifiedhacker.com 162.241.216.11
[*]  A certifiedhacker.com 162.241.216.11
[*]  TXT certifiedhacker.com v=spf1 a mx ptr
     include:bluehost.com ?all
[*] Enumerating SRV Records
[+]  SRV _caldavs._tcp.certifiedhacker.com ...
```

How to read it line by line:

- "std" = standard enumeration type (default).
- DNSSEC not configured: DNS answers are not signed, so DNS spoofing is easier.
- SOA and NS: the authoritative servers are Bluehost's; the domain is hosted there.
- Bind Version: the DNS server software (BIND) reveals a version string. Version info helps match vulnerabilities (this server may return a fake value).
- MX and A share the same IP: mail and web are on one host.
- TXT v=spf1 ... ?all: the SPF policy is "neutral" (?all), so spoofed mail from this domain is not rejected. Good for phishing.
- SRV records: list services such as CalDAV (calendar) over TLS, often from a cPanel host.

Real-world use: In two minutes the AI-driven DNSRecon run shows the tester the host, the mail server, a weak SPF policy, and missing DNSSEC.

AI angle: The AI handled install plus run. Watch for prompts that ask the AI to "install" tools; always check what package it installs.

Countermeasures and defense: Configure DNSSEC; set SPF to -all with DKIM and DMARC; hide BIND version (version.bind); restrict zone transfers.

EXAM FOCUS: "Which tool performs DNS enumeration, zone transfer tests, and reverse lookups?" -> DNSRecon. Flag recall: -d domain, -t type (std, axfr, brt, rvl, srv), -r range.

Memory trick: "DNSRecon = DNS RECONnaissance in one tool."

3.25 Reverse DNS Lookup

What it is: A forward lookup turns a name into an IP. A reverse DNS lookup turns an IP into a name. Attackers perform reverse DNS lookups on IP ranges to locate the DNS PTR records for those IP addresses.

- **PTR record:** the reverse record, stored in the special in-addr.arpa zone. 11.216.241.162.in-addr.arpa -> host name.

Analogy: Reverse phone lookup: you have a number and want to know whose number it is.

How it works:

1. Take an IP or a range found earlier (for example from Whois NetRange).
2. Ask DNS for the PTR record of each IP.
3. Names like vpn.example.com or mail01.example.com reveal what each IP does.

Tools on the slide: DNSRecon and "Reverse Lookup". The screenshot shows an MxToolbox SuperTool page with the query ptr:162.241.216.11 and a DNSRecon terminal (https://github.com) [tool name partly UNCLEAR on page 10; the web tool appears to be MxToolbox, https://mxtoolbox.com].

Commands:

```
dnsrecon -r 162.241.216.0-162.241.216.255
dnsrecon -r 162.241.216.0/24 -t rvl
dig -x 162.241.216.11
nslookup 162.241.216.11
```

- -r: the IP range to reverse-lookup.
- -t rvl: the reverse lookup type (optional with -r; verify).
- dig -x: dig's reverse lookup shortcut.

Sample output (shortened):

```
[*] Performing Reverse Lookup from 162.241.216.0 to
    162.241.216.255
[+]  PTR box5331.bluehost.com 162.241.216.11
[+]  PTR box5332.bluehost.com 162.241.216.12
[+] 2 Records Found
```

How to read it: each PTR line pairs a name with an IP. Here the names show shared hosting servers at Bluehost, so the target is on a shared host.

Countermeasures and defense: Use generic PTR names that do not describe the server's role; do not publish internal PTR records.

EXAM FOCUS: "Which DNS record does a reverse lookup query?" -> PTR. "Which dig option?" -> -x.

Memory trick: "PTR points back."

3.26 Traceroute

What it is: Traceroute programs work on the concept of the ICMP protocol and use the TTL field in the header of ICMP packets to discover the routers on the path to a target host.

- **ICMP (Internet Control Message Protocol):** a network layer protocol for error and control messages (ping uses it).
- **TTL (Time To Live):** a number in each IP packet header. Every router subtracts 1. When it reaches 0, the router drops the packet and sends back ICMP "Time Exceeded" (type 11).
- **Hop:** one router on the path.

Analogy: You send a letter with "deliver within 1 stop". The first post office returns it with its stamp. Next letter: "within 2 stops", and the second post office returns it. After a few letters you know every post office on the route.

How it works:

1. Send a packet with TTL = 1. The first router drops it and replies with ICMP Time Exceeded. Its IP is recorded as hop 1.
2. Send with TTL = 2. The second router replies. Hop 2 recorded.
3. Repeat, adding 1 each time, until the target replies (ICMP Echo Reply, or ICMP Port Unreachable for UDP, or SYN/ACK or RST for TCP).
4. Each hop line shows three round-trip times (three probes per hop by default).

Three kinds of traceroute on the slide:

Type	Typical command	Probe sent	Why use it
ICMP traceroute	tracert (Windows)	ICMP Echo Request	Default on Windows
TCP traceroute	tcptraceroute	TCP SYN, often port 80	Passes firewalls that block ICMP/UDP
UDP traceroute	traceroute (Linux)	UDP to high ports	Default on Linux and Unix

The commands on the slide are small [UNCLEAR on page 10]; the forms below are the standard ones (verify against the slide):

```
tracert www.certifiedhacker.com
traceroute www.certifiedhacker.com
sudo traceroute -I www.certifiedhacker.com
sudo traceroute -T -p 443 www.certifiedhacker.com
sudo tcptraceroute www.google.com 443
```

Sample output (Windows tracert, illustrative):

```
Tracing route to certifiedhacker.com [162.241.216.11]
over a maximum of 30 hops:
  1    1 ms    1 ms    1 ms  192.168.1.1
  2    9 ms    8 ms   10 ms  10.20.0.1
  3   12 ms   11 ms   12 ms  isp-core1.example.net
  4    *        *        *   Request timed out.
  5   40 ms   41 ms   39 ms  162.241.216.11
Trace complete.
```

How to read it:

- "maximum of 30 hops": default max TTL is 30.
- Each line = one hop. Three times = three probes.
- Hop 1 is usually your own gateway.
- "* * *" = no reply for that hop; often a firewall or a router that does not send ICMP Time Exceeded.
- The last hop is the target.

Real-world use: A tester runs ICMP and UDP traceroute; both stop at hop 4. He runs TCP traceroute on port 443 and reaches the web server. Conclusion: a firewall at hop 4 filters ICMP and UDP but allows HTTPS.

Countermeasures and defense: Block outgoing ICMP Time Exceeded at the border; filter inbound ICMP and unused UDP; use an IDS to alert on many probes with rising TTL.

EXAM FOCUS:

- "Which IP header field does traceroute use?" -> TTL.
- "Which ICMP message reveals each router?" -> Time Exceeded (type 11).
- "Windows tracert uses which protocol by default?" -> ICMP. "Linux traceroute?" -> UDP. "Best way past a firewall blocking ICMP?" -> TCP traceroute.
- Trap: traceroute is listed under network footprinting (active), not under scanning, in this module.

Memory trick: "TTL = Time To Leave a trail."

3.27 Traceroute with AI

What it is: ChatGPT or another generative AI can run traceroute from a plain-English prompt.

Prompt on the slide (small text, best reading [UNCLEAR on page 10]):

```
Perform network traceroute to discover the routers on the
path to a target host www.certifiedhacker.com
```

How it works:

1. sgpt --chat ... --shell with the prompt.

2. The AI generates traceroute www.certifiedhacker.com (Linux).
3. The tester presses E and reads the hop list.

AI angle: The AI can also explain each hop. Follow-up prompt: "Explain which hops in this traceroute output are likely firewalls and why."

EXAM FOCUS: The AI picks the tool; you must still know that traceroute discovers routers via TTL.

3.28 Traceroute Analysis

What it is: Attackers run traceroute to several hosts of the target and compare the results. By comparing which hop comes just before each host, they find the IP addresses of intermediate devices such as routers and firewalls between the source and the destination.

Analogy: If letters to three different houses all pass through the same post office just before delivery, that post office serves that street.

Example from the slide (five traceroute results):

1. traceroute 1.10.10.20 -> second to last hop is 1.10.10.1
2. traceroute 1.10.20.10 -> third to last hop is 1.10.10.1
3. traceroute 1.10.20.10 -> second to last hop is 1.10.10.50
4. traceroute 1.10.20.15 -> third to last hop is 1.10.10.1
5. traceroute 1.10.20.15 -> second to last hop is 1.10.10.50

How to work it out:

1. 1.10.10.1 is in every path, early. It is the border router.
2. 1.10.10.20 is reached right after the router, with nothing in between. It sits next to the router: the bastion host.
3. To reach 1.10.20.10 and 1.10.20.15, traffic goes router (1.10.10.1) -> 1.10.10.50 -> host. So 1.10.10.50 is a firewall in front of a second subnet (1.10.20.x).
4. 1.10.20.x is the DMZ (demilitarized zone): a separate network for public servers. 1.10.20.10 is the web server and 1.10.20.15 is the mail server.
5. The diagram also shows a second firewall (1.10.20.50) behind the DMZ that protects the internal network.

- **Bastion host:** a hardened server exposed to the internet, built to withstand attacks.
- **DMZ:** a buffer network between the internet and the internal network that holds public-facing servers.

Diagram (rebuilt from the slide):

```
Attacker
   |
Internet
   |
[Router 1.10.10.1]----[Bastion host 1.10.10.20]
   |
[Firewall 1.10.10.50]
   |
+------------- DMZ 1.10.20.x --------------+
|  [Web server 1.10.20.10]                 |
|  [Mail server 1.10.20.15]                |
+------------------------------------------+
   |
[Firewall 1.10.20.50]
   |
Internal network
```

Real-world use: Before scanning, a tester knows that the web and mail servers are behind one firewall and that the bastion host is directly exposed. He plans scans accordingly.

Countermeasures and defense: Block ICMP Time Exceeded from internal devices; use NAT so internal hop addresses are not visible.

EXAM FOCUS:

- Scenario: several traceroute results, "Which device is a firewall?" -> the hop that appears just before the DMZ hosts but not before the bastion host (1.10.10.50 here).
- Trap: the hop that appears in all paths (1.10.10.1) is the router, not the firewall.

Memory trick: "Shared by all = Router. Shared by DMZ only = Firewall."

3.29 Tracking Email Communications

What it is: Email tracking is used to monitor the delivery of emails to an intended recipient. Attackers track emails to gather information about a target recipient, such as IP addresses, geolocation, browser and OS details. They use it to build a hacking strategy and to perform social engineering and other attacks.

- **Email header:** the hidden part of an email that records its route and technical details. In most mail clients you see it with "Show original" or "View message source".
- **Tracking pixel:** a tiny invisible image in an email. When the recipient opens the mail, the image loads from the attacker's server, revealing IP, time, and browser or mail client (ADDED CONTEXT).

Analogy: An email header is the stamps and postmarks on an envelope. They show which post offices handled it and when. A tracking pixel is a "delivery receipt" that the receiver signs without knowing.

Information collected from an email header (from the slide):

1. The address from which the message was sent
2. Sender's IP address
3. Sender's mail server
4. Authentication system used by the sender's mail server
5. Date and time the message was received by the originator's email servers
6. Date and time the message was sent
7. Sender's full name

Sample header (illustrative):

```
Received: from mail.example.com (mail.example.com
  [203.0.113.25]) by mx.target.com with ESMTPS;
  Tue, 27 Oct 2026 09:14:02 +0000
From: "Jane Doe" <jane.doe@example.com>
Date: Tue, 27 Oct 2026 09:13:58 +0000
Authentication-Results: mx.target.com;
  spf=pass smtp.mailfrom=example.com;
  dkim=pass header.d=example.com; dmarc=pass
X-Mailer: Microsoft Outlook 16.0
```

How to read it:

- Received: shows the sender's mail server name and IP (203.0.113.25) and the time the receiving server got it. Read Received lines from the bottom up to follow the route.
- From: the sender's full name and address.
- Date: when the message was sent.
- Authentication-Results: the authentication system (SPF, DKIM, DMARC) and whether it passed.
- X-Mailer: the mail client and version, a hint about the sender's software.

> **ADDED CONTEXT:** Email tracking tools in the CEH courseware include eMailTrackerPro, Infoga, Mailtrack, and PoliteMail (verify). Email header analyzers include MxToolbox Header Analyzer and Google Admin Toolbox Messageheader.

Real-world use: An attacker sends a harmless newsletter with a tracking pixel to the IT manager. The pixel logs his home IP, city, and Outlook version. The attacker now picks an Outlook exploit and a local phishing theme.

Countermeasures and defense: Block automatic image loading in email clients; strip internal Received headers at the mail gateway; use SPF, DKIM, and DMARC.

EXAM FOCUS:

- "Which part of an email reveals the sender's IP address and mail server?" -> the email header (Received lines).

- "What can email tracking reveal?" -> IP, geolocation, browser and OS, time opened.
- Trap: the From: line can be forged easily; the Received chain added by servers is more reliable.

Memory trick: Header fields: "From, IP, Server, Auth, Received, Sent, Name" -> "Funny Ideas Sell After Really Smart Naming".

3.30 Footprinting through Social Engineering

What it is (simple words): Social engineering is the art of exploiting human behaviour to extract confidential information. Social engineers depend on the fact that people are unaware of the value of their information and are careless about protecting it.

Analogy: Instead of picking the lock, the burglar asks the cleaner to hold the door open.

What social engineers attempt to gather:

1. Credit card details and social security number
2. Usernames and passwords
3. Security products in use
4. Operating systems and software versions
5. Network layout information
6. IP addresses and names of servers

Techniques on the slide:

Technique	What it means	Example
Eavesdropping	Secretly listening to talks or reading messages	Overhearing staff in a cafe
Shoulder surfing	Watching someone type or read over their shoulder	Seeing a PIN typed at a desk
Dumpster diving	Searching trash for useful papers or devices	Finding printed network diagrams
Impersonation	Pretending to be someone trusted	Calling as "IT support"

How it works:

1. Pick a target person (help desk, receptionist, new hire).
2. Prepare a pretext (a believable story) using earlier recon.
3. Use one of the techniques to get information.
4. Use the information to fill gaps in the footprint or to gain access.

Real-world use: A tester dressed as a printer technician walks into the client office, looks at sticky notes on monitors (shoulder surfing), and checks the recycling bin (dumpster diving). He finds a printed VPN guide.

Countermeasures and defense: Security awareness training; clean desk policy; shred documents; verify identities with call-backs; privacy screens.

EXAM FOCUS:

- "Attacker looks through trash for information" -> dumpster diving. "Watches someone type" -> shoulder surfing. "Pretends to be IT" -> impersonation. "Listens secretly" -> eavesdropping.
- Trap: all four are active footprinting because they involve the target's people.

Memory trick: "EDSI: Ears, Dumpster, Shoulder, Identity" -> "Every Dog Sniffs Insects".

3.31 Footprinting Tools: Maltego and Recon-ng

What it is:

- **Maltego (https://www.maltego.com):** a tool that determines the relationships and real-world links between people, groups of people, organizations, websites, internet infrastructure, and documents. It shows them as a visual graph.
- **Recon-ng (https://github.com):** a web reconnaissance framework with independent modules and database interaction. It provides an environment in which open-source, web-based reconnaissance can be conducted. Its interface feels like Metasploit.

Key Maltego terms:

- **Entity:** one object on the graph, such as a domain, person, email, or IP.
- **Transform:** an action that takes one entity and finds related entities, for example "To DNS Name - MX" or "To Email addresses".
- **Graph:** the picture of entities and links.

Analogy: Maltego is a detective's wall with photos joined by red string. Recon-ng is a toolbox with labeled drawers; you open one drawer (module), use the tool, and the results go into one shared notebook (the database).

How Maltego works (from the demo, Maltego Community Edition):

1. Open a new graph and drag a Website or Domain entity onto it. The demo adds certifiedhacker.com ("Attackers add a website entity to target an organization").
2. Right-click the entity and run transforms, for example To Domains, To DNS Name - MX, To Email addresses, To Person.
3. New entities appear, linked to the first one. The demo shows entities pertaining to the owner of the domain.
4. The Output - Transform Output window logs each transform that ran.
5. Repeat on new entities to grow the map of people, domains, IPs, and documents.

How Recon-ng works (from the demo):

1. Start recon-ng and create or load a workspace (the prompt shows [recon-ng][CEH], so the workspace is CEH).
2. Install modules from the marketplace and list them.
3. Load the brute_hosts module, set the target domain, and run it.
4. The module tries common host names against the domain and stores found hosts in the workspace database.

Commands from the slide:

```
[recon-ng][CEH] > modules load recon/domains-hosts/brute_hosts
[recon-ng][CEH][brute_hosts] > run
```

The module list on the slide also shows recon/domains-domains/brute_suffix (finds other TLDs for the same name, for example example.net, example.org).

Sample output (as seen on the slide, shortened):

```
CERTIFIEDHACKER.COM
------------------
[*] No Wildcard DNS entry found.
[*] 02.certifiedhacker.com => No record found.
[*] 03.certifiedhacker.com => No record found.
[*] 1.certifiedhacker.com => No record found.
[*] 12.certifiedhacker.com => No record found.
```

How to read it: "No Wildcard DNS entry found" is good news for the attacker: the domain does not answer every name, so any name that resolves is real. Each line is one guessed host name. "No record found" means that guess does not exist. Found hosts appear with their IP and are saved (the slide labels this "Harvests list of target hosts").

Full Recon-ng workflow (ADDED CONTEXT, verify against your version 5.x):

```
recon-ng
[recon-ng][default] > workspaces create CEH
[recon-ng][CEH] > marketplace install all
[recon-ng][CEH] > modules search
[recon-ng][CEH] > modules load recon/domains-hosts/brute_hosts
[recon-ng][CEH][brute_hosts] > options set SOURCE certifiedhacker.com
[recon-ng][CEH][brute_hosts] > run
[recon-ng][CEH][brute_hosts] > back
[recon-ng][CEH] > show hosts
```

- **Wildcard DNS:** a DNS setting that answers any sub-domain name with an IP. It makes brute forcing useless, because every guess seems to exist.

Real-world use: A tester enters the client's domain in Maltego and in one hour has a graph linking 12 employees, 30 email addresses, 4 mail servers, and 2 forgotten domains. He then runs Recon-ng modules to confirm hosts and export a report.

Tools and commands used here: Maltego (transforms), Recon-ng (workspaces, marketplace, modules load, options set, run, show hosts).

Countermeasures and defense: Reduce public data that these tools correlate; monitor brute-force DNS queries at your DNS server.

EXAM FOCUS:

- "Which tool shows relationships and real-world links between people, organizations, and infrastructure as a graph?" -> Maltego.
- "Which web reconnaissance framework has independent modules and database interaction?" -> Recon-ng.
- Keywords: "entities", "transforms", "graph" -> Maltego. "Modules", "workspace", "marketplace" -> Recon-ng.
- Trap: Recon-ng is also the tool listed for "public source-code repositories" in the internet research table.

Memory trick: "Maltego Maps links. Recon-ng Runs modules."

3.32 Footprinting Tools: OSINT Framework and Other Tools

What it is: OSINT Framework (https://osintframework.com) is an open source intelligence gathering framework focused on gathering information from free tools or resources. It provides a simple web interface that lists OSINT tools arranged by category, shown as an OSINT tree structure.

Analogy: It is a map of a giant library. You click "Domain Name", then "Whois Records", and it points you to the right shelf of free tools.

Indicators next to tools:

Indicator	Meaning
(T)	Link to a tool that must be installed and run locally
(D)	Google Dork
(R)	Requires registration
(M)	URL holds the search term; edit the URL manually

Tree categories visible on the slide (small text, best reading): Username, Email Address, Domain Name, IP and MAC Address, Images/Videos/Docs, Social Networks, Instant Messaging, People Search Engines, Dating, Telephone Numbers, Public Records, Business Records, Transportation, Geolocation Tools/Maps, Search Engines, Forums/Blogs/IRC, Archives, Language Translation, Metadata, Mobile Emulation, Terrorism, Dark Web, Digital Currency, Classifieds, Encoding/Decoding, Tools, Malicious File Analysis, Exploits and Advisories, Threat Intelligence, OpSec, Documentation, Training.

The Domain Name branch is expanded on the slide: Whois Records, Subdomains, Discovery, Certificate Search, PassiveDNS, Reputation, Domain Blacklists, Typosquatting, Analytics, URL Expanders, Change Detection, Social Analysis, DNSSEC, Cloud Resources, Vulnerabilities, Tools, Report Malicious Sites. The leaf tools are too small to list reliably [UNCLEAR on page 12]; they include Whois services, Internet Archive Wayback Machine, Metagoofil (T), FOCA (T), and dark web items such as Tor2web.

How it works:

1. Open osintframework.com.
2. Click a category, then sub-categories, until you see tool links.
3. Read the indicator letters to know if you must install, register, or edit the URL.
4. Open the tool and search your target.

Other tools on the slide:

Tool	What it does (simple)
Sudomy	Sub-domain enumeration and analysis script
BillCipher	Information gathering tool for a website or IP
whatweb	Identifies web technologies (CMS, server, plugins)
Raccoon	Offensive recon and vulnerability scanning tool
Recon-Dog	All-in-one recon tool (Whois, DNS, ports, CMS)
Web Check	Website (web-check.xyz) giving a full site report
OSINT.SH	Website (osint.sh) with many OSINT lookups

These "other tools" descriptions are ADDED CONTEXT; the slide gives only names and URLs (github.com for the first five).

```
whatweb certifiedhacker.com
whatweb -v -a 3 certifiedhacker.com
```

- -v: verbose output. -a 3: aggression level 3 (aggressive, more requests; verify).

EXAM FOCUS:

- "In OSINT Framework, what does (T) mean?" -> tool must be installed and run locally. (D) -> Google dork. (R) -> requires registration. (M) -> URL must be edited manually.
- "Which tool identifies the CMS and web server of a site?" -> whatweb.

Memory trick: "T-D-R-M: Tool, Dork, Register, Manual" -> "Tiny Dogs Run Madly".

3.33 Collecting Information through Social Engineering on Social Networking Sites

What it is: Attackers use social engineering tricks to gather sensitive information from social networking websites. They create a fake profile, use the false identity to lure employees into revealing sensitive information, and collect information about employees' interests to trick them into revealing more.

- **Fake profile:** a social media account made to look like a real recruiter, colleague, or friend.

What users do vs what the attacker gets:

What users do	What attacker gets
Maintain profile	Contact info, location, etc.
Connect to friends, chat	Friends list, friends' info, etc.
Share photos and videos	Identity of family members, interests, etc.
Play games, join groups	Interests
Create events	Activities

What organizations do vs what the attacker gets:

What organizations do	What attacker gets
User surveys	Business strategies
Promote products	Product profile
User support	Social engineering
Recruitment	Platform/technology
Background check to hire employees	Type of business

Real-world use: An attacker builds a fake recruiter profile, connects to 40 engineers, and asks "which firewall stack do you work with?" during a fake interview.

Countermeasures and defense: Verify unknown connection requests; never discuss internal technology with strangers; set profiles to private.

EXAM FOCUS: "Recruitment posts give the attacker what?" -> platform/technology. "Sharing photos gives?" -> identity of family members and interests. Trap: "User support" gives the attacker social engineering opportunities, not technology details.

Memory trick: Organization rows: "Surveys show Strategy, Promotions show Products, Support gives Social engineering, Recruiting reveals Tech, Background checks reveal Business type."

3.34 Footprinting Tools: FOCA and subfinder

What it is:

- **FOCA (Fingerprinting Organizations with Collected Archives):** a Windows tool used mainly to find metadata and hidden information in the documents it scans. It searches Google, Bing, and DuckDuckGo for documents on the target domain (doc, docx, ppt, pdf, xls and more), downloads them, and extracts metadata. Source: https://www.elevenpaths.com.
- **subfinder:** a sub-domain discovery tool by ProjectDiscovery that helps find valid sub-domains for websites using passive online sources.
- **Metadata:** data about data. A Word file's metadata can hold the author's username, software version, printer name, internal file paths, and creation dates.

Analogy: FOCA reads the label on the back of every photo a company posted: who took it, with which camera, and where. subfinder asks many public phone books for every number listed under one company name.

How FOCA works (from the demo):

1. Create a project and enter the target domain (the demo uses eccouncil.org).
2. Pick search engines (Google, Bing, DuckDuckGo) and extensions (doc, ppt, pdf, xls and others).
3. Click Search All. FOCA lists matching document URLs with type, size, and download status ("Attackers obtain search results, displaying file information stored in the target domain").
4. Download the files and choose Extract Metadata, then Analyze Metadata.
5. The left tree ("View information of target domain") fills with Network (clients, servers), Domains, Roles, and a Metadata Summary: Users, Folders, Printers, Software, Emails, Operating Systems, Passwords, Servers.

How subfinder works:

1. Run subfinder with -d and the domain.
2. It queries passive sources (certificate logs, search engines, DNS datasets, APIs).
3. It removes duplicates and prints valid sub-domains.

Command from the slide:

```
subfinder -d certifiedhacker.com
```

Sample output (as seen on the slide, shortened):

```
[INF] Current subfinder version v2.x (verify)
[WRN] Use with caution. You are responsible for your
      actions.
[WRN] Developers assume no liability and are not
      responsible for any misuse or damage.
[INF] Enumerating subdomains for certifiedhacker.com
www.certifiedhacker.com
autodiscover.certifiedhacker.com
blog.certifiedhacker.com
cpanel.certifiedhacker.com
cpcalendars.certifiedhacker.com
webmail.certifiedhacker.com
www.demo.certifiedhacker.com
cpanel.demo.certifiedhacker.com
```

How to read it: [INF] lines are information, [WRN] lines are legal warnings. Every other line is one sub-domain. Names such as cpanel, webmail, and autodiscover reveal a cPanel hosting control panel, a webmail login, and Exchange/Outlook autodiscovery. "demo" sub-domains are test sites, often less protected.

Real-world use: FOCA finds 40 PDFs on a client site; metadata reveals usernames in the format jsmith and an internal file server path \FS01\HR. subfinder finds a forgotten demo site running an old CMS.

Tools used here: FOCA, subfinder. Related: Metagoofil and ExifTool (metadata, ADDED CONTEXT); Sublist3r, Amass (sub-domains).

Countermeasures and defense: Strip metadata before publishing documents (Document Inspector in Office, ExifTool, MAT2); remove old test and demo sub-domains.

EXAM FOCUS:

- "Which tool extracts metadata and hidden information from documents found on a target website?" -> FOCA.
- "FOCA stands for?" -> Fingerprinting Organizations with Collected Archives.
- "Which tool performs fast passive sub-domain discovery?" -> subfinder. Flag: -d domain; -o output file; -silent shows only results; -all uses all sources; -dL list of domains.
- Trap: FOCA finds metadata in documents; it is not a sub-domain tool, although it lists domains it sees in metadata.

Memory trick: "FOCA FOCuses on the Archives (documents)."

3.35 AI-Powered OSINT Tools

What it is: These are OSINT tools that use AI to gather, analyze, and interpret public data.

- **Taranis AI (https://taranis.ai):** an advanced open-source OSINT tool that leverages artificial intelligence to gather, analyze, and interpret publicly available data. It assists ethical hackers in identifying potential security threats,

vulnerabilities, and other relevant information from a wide array of sources on the internet.

- **OSS Insight (https://ossinsight.io):** uses AI to provide in-depth insights into the GitHub ecosystem, analyzing over 5 billion GitHub events. It offers tools for understanding and navigating the open-source world, from comprehensive repository analytics to developer productivity insights. Its "GitHub Data Explorer" lets you ask questions in plain English about GitHub repos, users, orgs, and languages.

Other AI tools on the slide (descriptions are ADDED CONTEXT, verify):

Tool	What it does (simple)
DorkGPT (dorkgpt.com)	Turns plain-English requests into Google dorks
DorkGenius (dorkgenius.com)	AI Google dork generator
Google Word Sniper	Builds advanced Google queries for word searches
Cylect.io	AI-assisted OSINT search across many sources
ChatPDF (chatpdf.com)	Chat with a PDF to summarize and extract facts

Analogy: Normal OSINT tools are fishing nets. AI OSINT tools are nets with a sorting machine attached that throws back the junk and labels the useful fish.

How it works:

1. Feed the tool a target, a topic, or a question in plain language.
2. The AI collects sources (news, feeds, repos, documents).
3. It summarizes, groups, and tags items (for example, threats against your industry).
4. The analyst reviews and acts.

Real-world use: A security team runs Taranis AI on news and advisory feeds to spot new attacks against their VPN vendor. A tester uses OSS Insight to find which developers contribute to the client's public repos, and ChatPDF to summarize a 200-page annual report in minutes.

AI angle: Attackers get the same speed. Example prompt for DorkGPT: "Find exposed login pages on example.com". For ChatPDF: "List every technology, vendor, and location mentioned in this report."

Countermeasures and defense: Assume attackers can read and summarize all your public documents instantly; publish less detail.

> **ADDED CONTEXT:** Recon data feeds AI-powered attacks covered in later modules: deepfake voice or video of an executive (built from public talks), AI-written spear phishing (WormGPT and FraudGPT style tools), and AI-generated fake profiles. AI recon tools are also attack surfaces: a web page can hide a prompt injection (OWASP LLM01) that tells an AI agent to ignore its task or leak data.

EXAM FOCUS:

- "Which AI-powered OSINT tool gathers, analyzes, and interprets public data to identify threats?" -> Taranis AI.
- "Which tool uses AI to analyze over 5 billion GitHub events?" -> OSS Insight.
- "Which tool generates Google dorks with AI?" -> DorkGPT or DorkGenius.

Memory trick: "Taranis = Threat radar. OSS Insight = Open Source Software insight."

3.36 Footprinting Countermeasures (Part 1)

What it is: Countermeasures are actions that reduce the information an organization leaks. Slide 52 lists seven.

1. Restrict the employees' access to social networking sites from the organization's network.
2. Configure web servers to avoid information leakage (for example, hide server version banners and error details).
3. Educate employees to use pseudonyms on blogs, groups, and forums.
4. Do not reveal critical information in press releases, annual reports, product catalogues, etc.
5. Limit the amount of information published on a website or the internet.
6. Use footprinting techniques to discover and remove any sensitive information that is publicly available.
7. Prevent search engines from caching a web page and use anonymous registration services.

- **Pseudonym:** a made-up name used instead of a real name.
- **Anonymous registration service:** a domain privacy service that shows the registrar's proxy details in Whois instead of the owner's.

Analogy: If burglars study your house from the street, you close the curtains, remove the name plate, and stop posting your holiday dates online.

How it works (example for item 7):

```
<meta name="robots" content="noarchive">
<meta name="robots" content="noindex, nofollow">
```

- noarchive: tells search engines not to keep a cached copy.

- noindex, nofollow: do not index the page and do not follow its links.

Real-world use: A company runs its own footprinting every quarter (item 6). It finds an old PDF price list with staff phone numbers, removes it, and requests removal from search results.

EXAM FOCUS: "Best way to stop attackers reading old cached copies of a page?" -> prevent caching (noarchive) and request removal. "Best defense against Whois-based social engineering?" -> anonymous/privacy registration.

Memory trick: "Restrict, Configure, Pseudonym, Press, Limit, Self-footprint, No-cache" -> "Really Clever People Prefer Limiting Self-Notes".

3.37 Create and Run a Custom Python Script to Automate Footprinting Tasks with AI

What it is: An attacker can leverage AI-powered ChatGPT or other generative AI to automate footprinting tasks by creating a custom Python script that runs automatically and fetches the required information.

Prompt on the slide (small text, best reading [UNCLEAR on page 14]):

```
Develop a Python script which will accept domain name
www.microsoft.com as input and execute a series of website
footprinting commands, including DNS lookups, WHOIS records
retrieval, email enumeration, and more, to gather
information about the target domain
```

How it works:

1. The tester sends the prompt with sgpt --code (or in ChatGPT) and saves the reply as footprint.py.
2. The script calls tools in order: DNS lookups (dig/nslookup), whois, email enumeration (theHarvester), and others.
3. The tester runs python3 footprint.py and reads the combined report.

Example of what such a script looks like (ADDED CONTEXT, simplified):

```
sgpt --code "Python script: take a domain, run dig, whois \
and theHarvester, save output to report.txt" > footprint.py
python3 footprint.py www.microsoft.com
```

```
import subprocess, sys
domain = sys.argv[1]
cmds = [
    ["dig", domain, "ANY", "+noall", "+answer"],
    ["whois", domain],
    ["theHarvester", "-d", domain, "-l", "100", "-b", "bing"],
]
with open("report.txt", "w") as out:
    for c in cmds:
        out.write("== " + " ".join(c) + " ==\n")
        r = subprocess.run(c, capture_output=True, text=True)
        out.write(r.stdout + "\n")
```

Line by line: it reads the domain from the command line, defines a list of commands, runs each one, and writes each command name and its output to report.txt.

Real-world use: A consultant who tests 20 client domains a month runs one AI-written script per domain and saves days of manual work.

AI angle: The AI writes code fast, but it can call tools that are not installed or use wrong flags. Read and test the script in a lab first. Never run AI code against a target outside the agreed scope.

EXAM FOCUS: "How can an attacker automate several footprinting tasks with AI?" -> ask an LLM to create a custom Python script that runs DNS, Whois, and email enumeration together.

Memory trick: "One prompt, one script, many tools."

3.38 Footprinting Countermeasures (Cont'd)

The 14 countermeasures on slide 53:

1. Develop and enforce security policies to regulate the information that employees can reveal to third parties.
2. Set apart internal and external DNS or use split DNS, and restrict zone transfer to authorized servers.
3. Disable directory listings in the web servers.
4. Conduct security awareness training periodically to educate employees about various social engineering tricks and risks.
5. Opt for privacy services on a Whois Lookup database.
6. Avoid domain-level cross-linking for critical assets.
7. Encrypt and password-protect sensitive information.
8. Place critical documents, such as business plans and proprietary documents, offline to prevent exploitation.
9. Train employees to thwart social engineering techniques and attacks.
10. Sanitize the details provided to internet registrars to hide the direct contact details of the organization.
11. Disable the geo-tagging functionality on cameras to prevent geolocation tracking.

12. Avoid revealing one's location or travel plans on social networking sites.
13. Turn off geolocation access on all mobile devices when not required.
14. Ensure that no critical information is displayed on notice boards or walls.

Key terms:

- **Split DNS:** two DNS views. Internal users see internal names; the internet sees only public names. Internal host names never leak.
- **Directory listing:** when a web folder has no index page, the server may show a list of all files in it ("Index of /"). Attackers love this.
- **Domain-level cross-linking:** linking critical internal assets from public pages or other domains, so a crawler can follow the links to them.
- **Geo-tagging:** GPS coordinates saved inside photo metadata (EXIF).

Countermeasure-to-attack mapping:

Countermeasure	Stops which footprinting method
Restrict zone transfer, split DNS	DNS interrogation and AXFR
Disable directory listing	Google dorks such as intitle:"index of"
Whois privacy, sanitize registrar data	Whois-based social engineering
Disable geo-tagging and geolocation	Photo and phone location tracking
Awareness training	Eavesdropping, impersonation, phishing
Offline critical documents, encryption	Document leaks and metadata mining

EXAM FOCUS:

- "Best countermeasure against DNS zone transfer footprinting?" -> restrict zone transfers to authorized (secondary) servers. Split DNS is the second-best answer.
- "Photos posted by staff reveal office location. Best fix?" -> disable geo-tagging on cameras.
- Trap: "Encrypt" does not stop footprinting of public data; pick the control that matches the leak.

Memory trick: Group the 14 into four buckets: "PEOPLE (policy, training x2, travel, notice boards), DNS/WEB (split DNS, zone transfer, directory listing, cross-linking), REGISTRY (Whois privacy, sanitize registrar), DATA (encrypt, offline, geo-tag, geolocation)".

4. Tool Encyclopedia

All tools below are used in the reconnaissance phase (phase 1) unless stated. "P" = passive use, "A" = active use. Tools not in the screenshots are marked (added).

4.1 Search Engines and Device Search

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Google advanced operators	Precise queries with site:, inurl:	Web	Recon P	"operator", "dork"
GHDB	Library of ready-made dorks	Web (exploit-db)	Recon P	"Google Hacking Database"
Bing, Yahoo, Ask, AOL	Other indexes, other results	Web	Recon P	"major search engines"
Baidu	Chinese search engine	Web	Recon P	theHarvester -b baidu
DuckDuckGo	Search without tracking	Web, default in Tor	Recon P	"privacy search"
SHODAN	Finds internet-connected devices	Web, CLI	Recon P	"webcam", "IoT", "banner"
Censys (added)	Device and certificate search	Web	Recon P	SHODAN alternative
DorkGPT, DorkGenius	AI dork generators	Web, AI	Recon P	"AI dork"
Google Word Sniper	Builds advanced Google queries	Web	Recon P	"word search queries"

4.2 Domains, Sub-domains and Websites

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Netcraft	Lists sub-domains, OS, netblock	Web	Recon P	"*.domain hostnames"
DNSdumpster	Finds hosts related to a domain	Web	Recon P	"discover hosts"
Sublist3r	Sub-domain enumeration via OSINT	Python CLI	Recon P/A	-d, -b brute force
subfinder	Fast passive sub-domain finder	Go CLI	Recon P	"valid subdomains"
Sudomy	Sub-domain enumeration script	Bash CLI	Recon P/A	"other tools" list

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
crt.sh (added)	Certificate transparency search	Web	Recon P	"certificate logs"
Wayback Machine	Old snapshots of websites	Web (archive.org)	Recon P	"archived versions"
Photon	Crawler that pulls archive.org URLs	Python CLI	Recon A	"archived URLs"
whatweb	Identifies web technologies	Ruby CLI	Recon A	"CMS, server type"
BillCipher	Info gathering on site or IP	Python CLI	Recon P/A	"other tools" list
Raccoon	Recon and vuln scanning	Python CLI	Recon A	"other tools" list
Recon-Dog	All-in-one recon wizard	Python CLI	Recon P/A	"other tools" list
Web Check	Full website report	Web	Recon P	web-check.xyz
OSINT.SH	Many OSINT lookups in one site	Web	Recon P	osint.sh

4.3 People, Business, Finance and Alerts

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Spokeo, Intelius, pipl	Person details, address, contacts	Web, paid	Recon P	"people search"
Dice, LinkedIn, Glassdoor	Job ads reveal infrastructure	Web	Recon P	"job sites"
Google Earth, Maps, Wikimapia	Physical location, entrances	Web, app	Recon P	"geographical location"
Google/MSN/ Yahoo! Finance	Stock, financial news	Web	Recon P	"financial services"
opencorporates, Crunchbase	Company profiles by region	Web	Recon P	"business profile"
corporationwiki	Company and officer links	Web	Recon P	"business profile"
Google/X/Giga Alerts	Auto updates on mentions	Web, email, SMS	Recon P	"monitoring alerts"
Mention, ReviewPush	Online reputation tracking	Web	Recon P	"reputation"
Reputology	Review and reputation tracking	Web	Recon P	"reputation"

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Google/LinkedIn Groups	Employee discussions	Web	Recon P	"groups, forums"

4.4 Social Media, Email and Dark Web

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Sherlock	Finds a username on 400+ sites	Python CLI	Recon P	"username across sites"
Social Searcher	Real-time social content search	Web	Recon P	"deep analytics"
BuzzSumo	Most shared content by topic	Web	Recon P	"most shared content"
Google Trends	Search popularity over time	Web	Recon P	"trends"
Hashatit	Hashtag search	Web	Recon P	"hashtags"
theHarvester	Emails, hosts, IPs from sources	Python CLI	Recon P	-d -l -b
Email Spider	Crawls sites for emails	Windows GUI	Recon P	"email list"
eMailTrackerPro (added)	Traces email from header	Windows GUI	Recon P	"email tracking"
Infoga (added)	Email OSINT (source, IP, breach)	Python CLI	Recon P	"email information"
Tor Browser	Anonymous browsing, .onion sites	Desktop browser	Recon P	"dark web access"
ExoneraTor	Was this IP a Tor relay?	Web (Tor Project)	Recon P	"Tor relay check"

4.5 Whois, Geolocation, DNS and Network

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
whois.domaintools.com	Whois record lookup	Web	Recon P	"Whois record"
whois command (added)	Whois from terminal, TCP 43	Linux CLI	Recon P	"registrant"
SmartWhois (added)	Desktop Whois client	Windows GUI	Recon P	"Whois GUI"
IP2Location	IP to city, ISP, time zone	Web	Recon P	"geolocation"

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
IP Location Finder	IP geolocation lookup	Web	Recon P	"geolocation"
SecurityTrails	Current and historic DNS data	Web	Recon P	"DNS history"
DNSChecker	DNS records from many places	Web	Recon P	"DNS records"
DNSRecon	DNS enum, AXFR, reverse, brute	Python CLI	Recon A	"DNS enumeration"
Fierce (added)	Finds hosts, tries AXFR	Perl CLI	Recon A	"non-contiguous IP"
dig, nslookup, host	Query DNS records	CLI	Recon A	"record type"
MxToolbox	Web DNS, PTR, header tools	Web	Recon P	"SuperTool"
tracert	ICMP traceroute	Windows CLI	Recon A	"ICMP, Windows"
traceroute	UDP traceroute (default)	Linux CLI	Recon A	"UDP, Linux"
tcptraceroute	TCP SYN traceroute	Linux CLI	Recon A	"bypass ICMP block"
Path Analyzer Pro (added)	Graphical traceroute	Windows GUI	Recon A	"traceroute GUI"
VisualRoute (added)	Traceroute on a map	GUI	Recon A	"traceroute map"

4.6 Frameworks, Metadata and AI

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
Maltego	Graph of links: people, domains	Java GUI	Recon P/A	"entities, transforms"
Recon-ng	Modular web recon framework	Python CLI	Recon P/A	"modules, workspace"
OSINT Framework	Tree of free OSINT tools	Web	Recon P	"(T)(D)(R)(M)"
FOCA	Metadata from documents	Windows GUI	Recon P	"metadata, documents"
Metagoofil (added)	Downloads docs, pulls metadata	Python CLI	Recon P	"metadata CLI"
ExifTool (added)	Reads and removes file metadata	CLI	Recon P	"EXIF, geo-tag"
ChatGPT	LLM for prompts, scripts, reports	Web, API	All phases	"generative AI"

Tool	What it does (simple)	Type or platform	Phase	Exam keyword
ShellGPT (sgpt)	LLM in the terminal	Python CLI	All phases	--shell, --chat
Taranis AI	AI OSINT, threat analysis	Web, open source	Recon P	"AI OSINT"
OSS Insight	AI GitHub analytics	Web	Recon P	"5 billion GitHub events"
Cylect.io	AI OSINT search	Web	Recon P	"AI search"
ChatPDF	Chat with PDF documents	Web, AI	Recon P	"summarize PDF"
lynx	Text-mode web browser	Linux CLI	Recon	"--dump page text"

> **EXAM TIP:** When two tools look right, match the exact verb: "relationships" -> Maltego, "modules" -> Recon-ng, "metadata" -> FOCA, "username" -> Sherlock, "emails" -> theHarvester, "devices" -> SHODAN, "archived URLs" -> Photon, "sub-domains and server OS" -> Netcraft.

5. Command Sheet

How to read any command: the first word is the program; words starting with - or -- are options (flags); a flag may take a value right after it; the rest are targets or arguments. The pipe symbol sends one command's output into the next command; > saves output to a file. Flags marked "verify" depend on the tool version.

5.1 ShellGPT (sgpt)

Purpose: Send a prompt to an LLM from the terminal and get text, a shell command, or code.

Full syntax:

```
sgpt [--chat NAME] [--shell] [--code] [--repl NAME] "PROMPT"
```

Breakdown: sgpt = program; --chat footprint = keep a named conversation called "footprint" so later prompts remember earlier ones; --shell = return a runnable shell command and offer to run it; "PROMPT" = your request in plain English.

Flag	Meaning	When to use	Example
--shell, -s	Output a shell command	Want a command to run	sgpt -s "list open ports"
--chat NAME	Named chat session with memory	Multi-step recon	--chat footprint
--code, -c	Output only code	Want a script	sgpt -c "python whois"
--repl NAME	Interactive chat loop	Many quick questions	sgpt --repl temp
--describe-shell, -d	Explain a command	Check what it does	sgpt -d "dig axfr"

Demo commands:

```
sgpt --chat footprint --shell "Use theHarvester to gather \
emails for example.com from bing, limit 100"
sgpt --code "python script to resolve a list of hostnames" \
  > resolve.py
```

Sample output:

```
theHarvester -d example.com -l 100 -b bing
[E]xecute, [D]escribe, [A]bort: E
```

Line 1 is the command the AI wrote. Line 2 is the menu: E runs it, D explains it, A cancels.

Common mistakes: pressing E without reading the command; forgetting quotes around the prompt; expecting the AI to know your target scope.

What the exam asks: which option makes ShellGPT produce a command (--shell); that AI can automate recon prompts in every phase; that the human must verify output.

5.2 Google Operator Queries and the lynx Pipeline

Purpose: Pull a list of result URLs for an operator query from the command line.

Full syntax:

```
lynx --dump "URL" | grep "PATTERN" | cut -d "DELIM" -f N \
  > FILE
```

Part	Meaning	When to use	Example
lynx --dump	Print a web page as plain text	Fetch result pages	lynx --dump "URL"
grep "url?q="	Keep lines matching a pattern	Filter result links	grep "url?q="
cut -d "=" -f2	Split at = and keep field 2	Extract the URL part	cut -d "=" -f2
> file	Save output to a file	Keep results	> recon1.txt

Demo (query parts): site:eccouncil.org+filetype:pdf. In a URL, + replaces spaces, so the query is "site:eccouncil.org filetype:pdf".

Common mistakes: Google blocks automated scraping and may return a CAPTCHA page, so the file can be empty; forgetting quotes around URLs with & in them.

What the exam asks: the operator part (site:, filetype:), not the Linux pipeline.

5.3 Sublist3r

Purpose: Enumerate sub-domains using search engines and OSINT services, with optional brute force.

```
sublist3r -d DOMAIN [-b] [-p PORTS] [-e ENGINES] [-t N] \
  [-v] [-o FILE]
```

Flag	Meaning	When to use	Example
-d	Target domain	Always	-d eccouncil.org
-b	Enable subbrute brute force	Want more names	-b
-p	Check found subs for TCP ports	Find live web hosts	-p 80,443
-e	Choose search engines	Limit sources	-e google,bing

Flag	Meaning	When to use	Example
-t	Threads for brute force	Speed up	-t 50
-v	Show results in real time	Watch progress	-v
-o	Save to text file	Keep results	-o subs.txt

Demo:

```
sublist3r -d eccouncil.org -o eccouncil_subs.txt
sublist3r -d eccouncil.org -b -t 30 -p 443
```

Sample output:

```
[-] Enumerating subdomains now for eccouncil.org
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Netcraft..
[-] Total Unique Subdomains Found: 4
aspen.eccouncil.org
cert.eccouncil.org
iclass.eccouncil.org
www.eccouncil.org
```

Each "Searching now in" line is one source. The total line gives the unique count; the list follows.

Common mistakes: confusing -b (brute force here) with theHarvester -b (source); some engines block the tool, giving fewer results.

What the exam asks: -d sets the domain; -b brute force; -p ports.

5.4 dig

Purpose: Query DNS servers for any record type; test zone transfers; do reverse lookups.

```
dig [@SERVER] NAME [TYPE] [+short] [+noall +answer]
dig -x IP
dig axfr @NAMESERVER DOMAIN
```

Part or flag	Meaning	When to use	Example
@server	Ask this DNS server	Query target NS directly	@ns1.example.com
TYPE	Record type to ask for	Pick a record	MX, NS, TXT, SOA
+short	Print only the answer values	Quick lists	dig example.com +short
+noall +answer	Show only the answer section	Clean output	+noall +answer

Part or flag	Meaning	When to use	Example
-x	Reverse lookup (PTR)	IP to name	dig -x 8.8.8.8
axfr	Request a full zone transfer	Test zone exposure	dig axfr @ns1 dom

Demo:

```
dig certifiedhacker.com MX +short
dig axfr @ns1.bluehost.com certifiedhacker.com
```

Sample output:

```
0 mail.certifiedhacker.com.

; <<>> DiG 9.18 <<>> axfr @ns1.bluehost.com certifiedhacker.com
; Transfer failed.
```

The first line: MX priority 0, mail server name. The second block: the server refused AXFR (good defense). If allowed, you would see every record in the zone.

Common mistakes: forgetting @ before the server; expecting dig ANY to list every sub-domain.

What the exam asks: which command tests zone transfer (dig axfr, or nslookup then ls -d); -x for reverse.

5.5 nslookup and host (ADDED CONTEXT)

Purpose: Simple DNS queries; nslookup works on Windows and Linux.

```
nslookup -type=TYPE NAME [SERVER]
host -t TYPE NAME
```

Command or flag	Meaning	When to use	Example
-type=mx	Record type	Mail servers	nslookup -type=mx dom
server X	Interactive: change server	Ask target NS	server ns1.dom
set type=any	Interactive: any type	Broad query	set type=any
ls -d dom	Interactive: zone transfer	Old Windows test	ls -d example.com
host -t ns	Name server lookup	Quick Linux query	host -t ns dom
host -l	Zone transfer with host	AXFR test	host -l dom ns1.dom

Sample output:

```
Non-authoritative answer:
certifiedhacker.com  mail exchanger = 0 mail.certifiedhacker.com.
```

"Non-authoritative" means a caching resolver answered, not the domain's own name server.

What the exam asks: "set type=mx" and "ls -d" meanings; authoritative vs non-authoritative answer.

5.6 Photon

Purpose: Crawl a website and extract URLs, files, emails, social accounts, and keys; optionally seed with archive.org URLs.

```
python3 photon.py -u URL [-l LEVEL] [-t THREADS] [-o DIR] \
  [--wayback] [--keys] [--dns] [--clone]
```

Flag	Meaning	When to use	Example
-u	Root URL to crawl	Always	-u https://example.com
-l	Crawl depth (default 2)	Go deeper	-l 3
-t	Threads (default 2)	Speed up	-t 10
-o	Output directory	Save results	-o out_dir
--wayback	Use archive.org URLs as seeds	Find old pages	--wayback
--keys	Look for API keys and secrets	Hunt leaked keys	--keys
--dns	Save sub-domains and DNS map	Quick DNS picture	--dns
--clone	Save the site locally	Offline review	--clone

Demo:

```
python3 photon.py -u https://www.example.com --wayback -o ex
```

Sample output:

```
[~] Fetching URLs from archive.org
[+] Retrieved 412 URLs from archive.org
[~] Crawling 412 URLs
[+] Intel: 6
[+] Files: 18
[+] Endpoints: 57
[!] Results saved in ex directory
```

"Retrieved ... from archive.org" confirms --wayback worked. Intel = emails and social accounts. Files = documents found. Endpoints = URLs with parameters (possible test points later).

Common mistakes: too many threads can overload a small site (that is no longer passive).

What the exam asks: "Which tool retrieves archived URLs from archive.org?" -> Photon.

5.7 theHarvester

Purpose: Gather emails, host names, IPs, and URLs for a domain from public sources.

```
theHarvester -d DOMAIN -b SOURCE [-l LIMIT] [-S START] \
  [-f FILE]
```

Flag	Meaning	When to use	Example
-d	Domain or company to search	Always	-d microsoft.com
-b	Data source(s), or all	Pick sources	-b baidu
-l	Limit results (default 500)	Control volume	-l 200
-S	Start at result number	Skip results	-S 100
-f	Save results to file	Keep a report	-f ms_report
-n	Reverse DNS on found ranges	More hosts (active)	-n
-c	DNS brute force	More hosts (active)	-c
-s	Use Shodan for found hosts	Add port info	-s

Newer versions add -r (DNS resolution) and use -t for takeover checks (verify for your version).

Demo:

```
theHarvester -d microsoft.com -l 200 -b baidu
theHarvester -d example.com -b bing,crtsh -l 300 -f ex
```

Sample output: see section 3.17. Read "Emails found" and "Hosts found" blocks.

Common mistakes: forgetting -b in older versions (required); using a source that needs an API key without setting it.

What the exam asks: what -d, -l, -b mean; that it gathers emails for phishing and brute force.

5.8 Sherlock

Purpose: Find which social sites have an account with a given username.

```
sherlock USERNAME [USERNAME ...] [-o FILE] [--print-found] \
  [--timeout SEC] [--site NAME] [--csv]
```

Flag	Meaning	When to use	Example
USERNAME	One or more names to check	Always	sherlock jdoe
-o, --output	Save results (one user)	Keep a file	-o recon2.txt
--print-found	Show only found sites	Cleaner output	--print-found
--timeout	Seconds to wait per site	Slow networks	--timeout 10
--site	Check only given sites	Focused check	--site GitHub
--csv	Also write a CSV file	Spreadsheet	--csv
--proxy, -p	Send requests via a proxy	Hide source IP	-p socks5://...

Demo:

```
sherlock SundarPichai --print-found -o recon2.txt
```

Sample output: see section 3.19. Each [+] line = account found.

Common mistakes: names with spaces are not usual usernames; many hits are false positives.

What the exam asks: tool choice ("search a username across many social sites").

5.9 whois (ADDED CONTEXT)

Purpose: Look up domain or IP registration data from the terminal (TCP port 43).

```
whois [-h SERVER] DOMAIN_OR_IP
```

Flag	Meaning	When to use	Example
(none)	Auto-pick the right server	Normal use	whois example.com
-h	Ask a specific Whois server	Query an RIR	-h whois.ripe.net
-p	Use another port	Rare servers	-p 43

Sample output for an IP:

```
NetRange:   162.240.0.0 - 162.255.255.255
CIDR:       162.240.0.0/12
OrgName:    Unified Layer
Country:    US
```

NetRange and CIDR give the owner's address block; OrgName is the hosting company. (Values illustrative, verify.)

What the exam asks: what Whois returns; that RIRs hold IP Whois data.

5.10 DNSRecon

Purpose: Full DNS enumeration: standard records, zone transfer, brute force, reverse lookups, SRV records.

```
dnsrecon -d DOMAIN [-t TYPE] [-r RANGE] [-D WORDLIST] \
  [-n NS] [-j FILE] [-x FILE]
```

Flag	Meaning	When to use	Example
-d	Target domain	Most types	-d certifiedhacker.com
-t std	Standard records (default)	First run	-t std
-t axfr	Test zone transfer on all NS	Zone exposure	-t axfr
-t brt	Brute force names	Find hidden hosts	-t brt -D subs.txt
-t rvl	Reverse lookup of a range	Map PTR names	-t rvl -r 1.2.3.0/24
-t srv	SRV record enumeration	Find services	-t srv
-r	IP range for reverse lookup	With rvl	-r 10.0.0.1-10.0.0.50
-D	Word list for brute force	With brt	-D names.txt
-n	DNS server to use	Ask target NS	-n 8.8.8.8
-j, -x	Save as JSON or XML	Reports	-j out.json

Demo:

```
dnsrecon -d certifiedhacker.com -t axfr
dnsrecon -r 162.241.216.0/24
```

Sample output (zone transfer test):

```
[*] Checking for Zone Transfer for certifiedhacker.com
[*] Trying NS server 162.159.24.80
[-] Zone Transfer Failed for 162.159.24.80!
[-] Zone Transfer Failed for 162.159.25.175!
```

Each name server is tested. "Failed" means transfers are restricted (good defense).

Common mistakes: forgetting -D with brt; running rvl without -r.

What the exam asks: DNSRecon for DNS enumeration and reverse lookup; -t axfr; -r range.

5.11 tracert (Windows)

Purpose: Show the routers on the path to a host using ICMP Echo Requests with rising TTL.

```
tracert [-d] [-h MAXHOPS] [-w TIMEOUT_MS] TARGET
```

Flag	Meaning	When to use	Example
-d	Do not resolve IPs to names	Faster, quieter	tracert -d host
-h	Max hops (default 30)	Long paths	-h 40
-w	Wait time per reply in ms	Slow links	-w 2000
-4 / -6	Force IPv4 or IPv6	Dual-stack hosts	-4

Demo:

```
tracert -d www.certifiedhacker.com
```

Sample output and reading: see section 3.26.

5.12 traceroute (Linux) and tcptraceroute

Purpose: Same goal; Linux default probe is UDP to high ports (starting 33434); options switch to ICMP or TCP.

```
traceroute [-I] [-T] [-p PORT] [-n] [-m MAXTTL] [-q N] HOST
tcptraceroute HOST [PORT]
```

Flag	Meaning	When to use	Example
(none)	UDP probes	Default	traceroute host
-I	Use ICMP Echo	UDP is blocked	sudo traceroute -I host
-T	Use TCP SYN	Firewalls block ICMP/ UDP	sudo traceroute -T host
-p	Port for probes	With -T pick 80/443	-T -p 443
-n	No name resolution	Faster output	-n
-m	Max TTL (default 30)	Long paths	-m 40
-q	Probes per hop (default 3)	Fewer packets	-q 1

Demo:

```
sudo traceroute -T -p 443 -n www.certifiedhacker.com
sudo tcptraceroute www.certifiedhacker.com 443
```

Sample output:

```
traceroute to www.certifiedhacker.com (162.241.216.11),
30 hops max, 60 byte packets
 1  192.168.1.1  0.9 ms  0.8 ms  0.8 ms
 2  10.20.0.1  8.7 ms  8.5 ms  8.9 ms
 3  * * *
 4  162.241.216.11  40.1 ms  39.8 ms  40.3 ms
```

Line 1: target, max hops, packet size. Hops 1-2 answered. Hop 3 is silent (filters probes). Hop 4 is the target, reached on TCP 443.

Common mistakes: -I and -T need root (sudo); "* * *" does not mean the host is down.

What the exam asks: TTL field; ICMP Time Exceeded; tracert = ICMP; traceroute = UDP; TCP traceroute passes firewalls.

5.13 Recon-ng

Purpose: Run recon modules inside one framework; results go into a workspace database.

```
recon-ng [-w WORKSPACE]
> workspaces create NAME
> marketplace install MODULE_PATH
> modules load MODULE_PATH
> options set SOURCE VALUE
> run
> show hosts
```

Command	Meaning	When to use	Example
workspaces create	Make a new project space	Start of a job	workspaces create CEH
marketplace search	List available modules	Find a module	marketplace search hosts
marketplace install	Install a module	Before loading	marketplace install all
modules load	Select a module	Pick a task	modules load .../ brute_hosts
options set SOURCE	Set the module input	Choose target	options set SOURCE dom
run	Execute the loaded module	Start the task	run
show hosts	List hosts in database	Review results	show hosts
back	Leave the module	Pick another	back

Demo: see section 3.31 (brute_hosts on certifiedhacker.com).

Sample output (show hosts):

```
  | rowid | host                     | ip_address     |
  | 1     | www.certifiedhacker.com  | 162.241.216.11 |
  | 2     | mail.certifiedhacker.com | 162.241.216.11 |
```

Each row is a host the modules stored, with its IP.

Common mistakes: loading a module before installing it from the marketplace; forgetting to set SOURCE (it uses default domains from the database).

What the exam asks: that Recon-ng is a modular framework with a database; module names such as recon/domains-hosts/brute_hosts.

5.14 subfinder

Purpose: Fast passive sub-domain discovery.

```
subfinder -d DOMAIN [-o FILE] [-silent] [-all] [-recursive]
subfinder -dL domains.txt -o out.txt
```

Flag	Meaning	When to use	Example
-d	Target domain	Always	-d certifiedhacker.com
-dL	File with many domains	Many targets	-dL list.txt
-o	Write results to file	Keep results	-o subs.txt
-silent	Print only sub-domains	Pipe to other tools	-silent
-all	Use all sources (slow)	Max coverage	-all
-recursive	Sources that go deeper	Nested subs	-recursive
-nW, -active	Show only live sub-domains	Filter dead names	-nW

Demo:

```
subfinder -d certifiedhacker.com -silent -o subs.txt
```

Sample output: see section 3.34.

What the exam asks: subfinder = sub-domain discovery; -d.

5.15 whatweb

Purpose: Identify the technologies of a website.

```
whatweb [-v] [-a LEVEL] URL
```

Flag	Meaning	When to use	Example
-v	Verbose, plugin details	Full report	-v
-a 1	Stealthy, one request (default)	Quiet check	-a 1
-a 3	Aggressive, more requests	More detail	-a 3

Sample output:

```
http://certifiedhacker.com [200 OK] Apache, Country[US],
HTTPServer[Apache], IP[162.241.216.11], PHP[7.4],
Title[Certified Hacker], WordPress[6.x]
```

Read each bracket: status, server, country, IP, language version, page title, CMS. Values here are illustrative.

6. Ports, Protocols, Standards and Acronyms

6.1 Protocols and Ports

Protocol	Simple purpose	Port or layer	Known weakness	Related attack or tool
DNS	Names to IPs	UDP/TCP 53, app layer	Open zone transfer	dig, DNSRecon, Fierce
DNS zone transfer	Copy a zone to secondary	TCP 53	Leaks all hosts	dig axfr, nslookup ls -d
Whois	Domain and IP owner lookup	TCP 43	Personal data exposed	whois, DomainTools
ICMP	Errors and echo (ping)	Network layer (no port)	Reveals routers via TTL	tracert, traceroute -I
UDP	Fast connectionless transport	Transport layer	Probes to high ports	traceroute (Linux)
TCP	Reliable connection transport	Transport layer	SYN probes pass firewalls	tcptraceroute
HTTP / HTTPS	Web pages	TCP 80 / 443	Banners, directory listing	whatweb, Photon
SMTP	Sends email	TCP 25 (587 submit)	Headers reveal IPs	Email header analysis
RTSP	Streams camera video	TCP 554	Default logins, no auth	SHODAN port:554
SSH	Secure remote login	TCP 22	Leaked private keys	Repo secret search
Tor	Onion routing for anonymity	Overlay network	Hides attackers	Tor Browser, ExoneraTor

Rare protocols and services, short introductions:

- **RTSP (Real Time Streaming Protocol):** controls video streams from IP cameras and DVRs. Security teams and homeowners use it. Attackers care because many cameras expose it with no password; SHODAN shows them under port 554.
- **ICMP Time Exceeded (type 11):** the message a router sends when TTL hits 0. Network tools use it for diagnosis. Attackers care because it reveals each router's IP.
- **AXFR (full zone transfer):** used between primary and secondary DNS servers to keep copies in sync. Attackers care because an open AXFR gives a full host list in one query.

- **DNSSEC:** adds digital signatures to DNS answers so clients can verify them. Attackers care because when it is missing (as in the DNSRecon demo), DNS spoofing is easier.
- **SPF, DKIM, DMARC:** email authentication records in DNS TXT. Mail providers use them to reject spoofed mail. Attackers care because a weak SPF (?all) or missing DMARC makes spoofing the domain easier.
- **CalDAV / CardDAV (SRV records):** calendar and contact sync protocols, often on cPanel hosts. They show up as SRV records and reveal extra services.

6.2 DNS Record Types

Record	Purpose	Example value	Why attackers care
A	Host to IPv4	162.241.216.11	Target IP
AAAA (added)	Host to IPv6	2001:db8::10	IPv6 targets often less filtered
MX	Mail server	mail.example.com	Phishing, mail attacks
NS	Name server	ns1.example.com	Zone transfer target
CNAME	Alias	www -> example.com	Hidden services, takeover
SOA	Zone authority, admin email	ns1, admin.example.com	Primary NS, admin contact
SRV	Service location	_sip._tcp	Reveals services
PTR	IP to host	11.216... -> host	Names reveal roles
RP	Responsible person	admin.example.com	Social engineering contact
HINFO	CPU and OS	INTEL Windows	Exploit selection
TXT	Free text, SPF, DKIM	v=spf1 ...	Vendors, mail policy

6.3 Regional Internet Registries

RIR	Region	Whois server
ARIN	North America (US, Canada, part of Caribbean)	whois.arin.net
AFRINIC	Africa	whois.afrinic.net
RIPE NCC	Europe, Middle East, Central Asia	whois.ripe.net
LACNIC	Latin America, part of Caribbean	whois.lacnic.net
APNIC	Asia Pacific	whois.apnic.net

6.4 Acronyms

Acronym	Meaning
OSINT	Open-Source Intelligence

Acronym	Meaning
TOE	Target of Evaluation
GHDB	Google Hacking Database
SHODAN	Sentient Hyper-Optimized Data Access Network (verify)
TLD	Top-Level Domain
RIR	Regional Internet Registry
ARIN	American Registry for Internet Numbers
AFRINIC	African Network Information Centre
RIPE NCC	Reseaux IP Europeens Network Coordination Centre
LACNIC	Latin America and Caribbean Network Information Centre
APNIC	Asia Pacific Network Information Centre
DNS	Domain Name System
TTL	Time To Live
ICMP	Internet Control Message Protocol
ISP	Internet Service Provider
IDD	International Direct Dialing
DMZ	Demilitarized Zone
FOCA	Fingerprinting Organizations with Collected Archives
LLM	Large Language Model
sgpt	ShellGPT
SSN	Social Security Number
EXIF	Exchangeable Image File Format (photo metadata)
HINFO	Host Information record
RP	Responsible Person record
SOA	Start of Authority record
PTR	Pointer record
CNAME	Canonical Name record
MX	Mail Exchange record
SRV	Service record
AXFR	Full zone transfer
SPF	Sender Policy Framework
DKIM	DomainKeys Identified Mail
DMARC	Domain-based Message Authentication, Reporting and Conformance

Acronym	Meaning
RTSP	Real Time Streaming Protocol
CMS	Content Management System

7. Attack vs Countermeasure and Look-alike Comparisons

7.1 Footprinting Technique vs Countermeasure

Footprinting technique	What leaks	Best countermeasure
Google hacking (dorks)	Files, login pages, directory lists	Remove data, noindex, disable directory listing
Cached and archived pages	Old content	Prevent caching, request removal
SHODAN device search	Exposed cameras, admin panels	Remove from internet, VPN, change defaults
Sub-domain discovery	Forgotten hosts	Inventory and remove old sub-domains, split DNS
People search, job sites	Names, tech stack	Generic job ads, opt-out requests
Dark web searching	Leaked credentials	Dark web monitoring, MFA, resets
Social media analysis	Interests, contacts	Training, private profiles, pseudonyms
Email harvesting	Address lists	Role addresses, obfuscation, MFA
Whois lookup	Owner contact details	Privacy service, sanitize registrar data
DNS interrogation, AXFR	All host names	Restrict zone transfer, split DNS
Reverse DNS	Server roles from names	Generic PTR names
Traceroute	Routers and firewalls	Block ICMP Time Exceeded outbound
Email tracking	IP, location, client	Block remote images, strip headers
Social engineering	Passwords, layouts	Awareness training, verification, shredding
Document metadata (FOCA)	Usernames, paths, software	Strip metadata before publishing
Photo geo-tags	Locations	Disable geo-tagging, turn off geolocation
Source-code repos	Keys, configs	Secret scanning, key rotation

7.2 Look-alike Pairs

X vs Y	Difference in one line	How to tell in a question
Passive vs active recon	No contact vs direct contact	"Queried their server/called staff" = active

X vs Y	Difference in one line	How to tell in a question
Footprinting vs scanning	Collect info vs probe live hosts	Port lists, ping sweeps = scanning phase
intitle: vs allintitle:	One word vs all words in title	Count the words that must match
inurl: vs allinurl:	One word vs all words in URL	Same rule as title
link: vs related:	Pages linking to vs similar pages	"points to" vs "similar"
cache: vs Wayback	Latest copy vs many dated copies	"history over years" = Wayback
SHODAN vs Google	Devices and banners vs web pages	"webcam, IoT, port" = SHODAN
Netcraft vs DNSdumpster	Sites with OS vs DNS host map	"OS and netblock" = Netcraft
Sublist3r vs subfinder	OSINT plus brute force vs passive only	"brute force module" = Sublist3r
theHarvester vs Sherlock	Emails of a domain vs one username	"email list" vs "username"
Sherlock vs Social Searcher	Find accounts vs read posts	"real-time content" = Social Searcher
BuzzSumo vs Google Trends	Most shared content vs search popularity	"shared most" = BuzzSumo
Maltego vs Recon-ng	Visual link graph vs CLI modules	"graph, transforms" = Maltego
FOCA vs Photon	Document metadata vs crawl and archive URLs	"metadata" = FOCA
Whois vs DNS lookup	Owner registration vs host records	"registrant, expiry" = Whois
NS vs SOA	Name servers vs zone authority details	"serial, admin email" = SOA
A vs PTR	Name to IP vs IP to name	"reverse" = PTR
tracert vs traceroute	Windows ICMP vs Linux UDP default	Check the OS in the question
Deep web vs dark web	Not indexed vs hidden, needs Tor	".onion, anonymous" = dark web
Tor Browser vs ExoneraTor	Browse anonymously vs check relay IP	"was IP a Tor relay" = ExoneraTor
Shoulder surfing vs eavesdropping	Watching vs listening	"looked at screen" vs "overheard"
Taranis AI vs OSS Insight	AI threat OSINT vs AI GitHub analytics	"GitHub events" = OSS Insight

8. Exam Cheat Sheet

8.1 Keyword -> Answer

If the question says	Think
"without direct interaction", "public sources"	Passive footprinting
"queried DNS server", "called help desk", "port scan"	Active footprinting
"restrict results to a domain"	site:
"only PDF/XLS files"	filetype:
"stored copy of page"	cache:
"pages similar to"	related:
"pages that link to"	link:
"word in the title / URL"	intitle: / inurl:
"all words in the title / URL"	allintitle: / allinurl:
"ready-made dorks"	GHDB
"webcams, IoT, banners, SCADA"	SHODAN
"sub-domains and OS of web servers"	Netcraft
"discover hosts related to a domain"	DNSdumpster
"archived versions of a website"	Wayback Machine (archive.org)
"retrieve archived URLs"	Photon
"person's address, contacts, dates"	Spokeo, Intelius, pipl
"infrastructure from job ads"	Dice, LinkedIn, Glassdoor
"browse anonymously, .onion"	Tor Browser
"non-interfering, subtle, competitors"	Competitive intelligence
"entrances, cameras, fences"	Google Earth, Google Maps, Wikimapia
"alerts by email or SMS"	Google Alerts
"company reputation online"	Mention, ReviewPush, Reputology
"SSH keys, config files in repos"	Public source-code repositories (Recon-ng)
"collect email addresses"	theHarvester, Email Spider
"most shared content"	BuzzSumo
"username across social sites"	Sherlock
"registrant, expiry, NetRange"	Whois
"CPU type and OS in DNS"	HINFO
"IP to host name"	PTR, reverse DNS
"city, ISP, time zone of an IP"	IP2Location
"routers on the path, TTL"	Traceroute

If the question says	Think
"sender IP and mail server"	Email header
"trash", "over the shoulder"	Dumpster diving, shoulder surfing
"relationships, entities, transforms"	Maltego
"modules, workspace, marketplace"	Recon-ng
"(T) (D) (R) (M) indicators"	OSINT Framework
"metadata in documents"	FOCA
"passive subdomain discovery"	subfinder
"AI OSINT threat analysis"	Taranis AI
"AI over 5 billion GitHub events"	OSS Insight
"zone transfer defense"	Restrict zone transfer, split DNS
"hide registrant contact"	Whois privacy service

8.2 Must-memorize Lists and Numbers

- Recon types: 2 (passive, active).
- Information groups: 3 (organization, network, system).
- Whois returns: 7 items (domain details, owner contacts, name servers, NetRange, created, expiry, last updated).
- RIRs: 5 (ARIN, AFRINIC, RIPE NCC, LACNIC, APNIC).
- DNS record types on slide: 10 (A, MX, NS, CNAME, SOA, SRV, PTR, RP, HINFO, TXT).
- Email header items: 7.
- Social engineering techniques: 4 (eavesdropping, shoulder surfing, dumpster diving, impersonation).
- Competitive intelligence sources: 10.
- OSINT Framework indicators: 4 (T, D, R, M).
- Countermeasures: 7 + 14 = 21.
- Ports: DNS 53 (zone transfer TCP 53), Whois 43, HTTP 80, HTTPS 443, SMTP 25, RTSP 554, SSH 22.
- Traceroute defaults: 30 max hops, 3 probes per hop, Linux UDP start port 33434.
- theHarvester default limit 500; Photon default depth 2 (verify for your version).

8.3 "Pick the BEST option" Rules for This Module

1. If the question stresses "stealth" or "no detection", choose a passive method or tool.
2. If several tools fit, choose the one whose main purpose matches the verb in the question.
3. For "first step" in footprinting, choose passive information gathering (search engines, website, Whois) before anything active.
4. For DNS leaks, "restrict zone transfers to authorized servers" beats "use a firewall".
5. For traceroute blocked by a firewall, choose TCP traceroute on an allowed port (80/443).

6. For document leaks, "remove metadata before publishing" beats "encrypt documents".
7. For social engineering, "security awareness training" is the classic best answer.
8. AI tools speed up the same techniques; the technique (operator, tool) is still the answer the exam wants.

9. Practice Questions

These are original practice questions written for this guide. They are not real exam questions. The answer and explanation sit directly below each question.

Q1. A penetration tester is hired to assess a regional bank. On day one she reads the bank's website, its annual report, employee LinkedIn profiles, and Whois records. She never sends a packet to the bank's systems. Which type of reconnaissance is she performing?

- A. Active reconnaissance
- B. Passive reconnaissance
- C. Enumeration
- D. Vulnerability scanning

Answer: B. She uses only public sources with no direct interaction, which is passive reconnaissance.

- A is wrong: active recon needs direct interaction (DNS interrogation, calls, scans).
- C is wrong: enumeration connects to target services to pull users and shares.
- D is wrong: vulnerability scanning sends probes to target systems.

Q2. An attacker wants Google to return only PDF documents hosted on example.com. Which query is BEST?

- A. inurl:example.com pdf
- B. site:example.com filetype:pdf
- C. related:example.com pdf
- D. intitle:pdf example.com

Answer: B. site: limits results to the domain and filetype: limits them to PDF files.

- A is wrong: inurl: matches text in URLs, so it also returns other sites that mention example.com.
- C is wrong: related: shows sites similar to example.com.
- D is wrong: intitle: looks at page titles, not file types.

Q3. Which Google operator restricts results to pages that contain ALL of the given keywords in the page title?

- A. intitle:
- B. allinurl:
- C. allintitle:
- D. info:

Answer: C. allintitle: requires every listed word to be in the title.

- A is wrong: intitle: requires only the word right after it.
- B is wrong: allinurl: checks the URL, not the title.
- D is wrong: info: shows what Google knows about one page.

Q4. A security analyst wants to find internet-connected IP cameras and DVRs in her company's IP range, including their banners and open ports, without scanning them herself. Which tool is the BEST choice?

- A. Netcraft
- B. SHODAN
- C. theHarvester
- D. Wayback Machine

Answer: B. SHODAN indexes devices and their banners and ports; searching it does not send traffic to the devices.

- A is wrong: Netcraft focuses on websites, sub-domains, and hosting OS.
- C is wrong: theHarvester collects emails and host names.
- D is wrong: the Wayback Machine stores old copies of web pages.

Q5. A tester runs the following command. What does the -b option do here?

```
theHarvester -d microsoft.com -l 200 -b baidu
```

- A. Enables brute-force of sub-domains
- B. Sets Baidu as the data source
- C. Sets the output file name
- D. Runs in background mode

Answer: B. In theHarvester, -b chooses the data source; -d is the domain and -l the result limit.

- A is wrong: brute force with -b is a Sublist3r option; theHarvester uses -c for DNS brute force.
- C is wrong: -f sets the output file.
- D is wrong: there is no background option here.

Q6. A company deleted its staff directory page two years ago. An attacker still obtains the names and email format from that page. Which resource did he MOST likely use?

- A. Google cache: operator
- B. archive.org Wayback Machine
- C. SHODAN
- D. ExoneraTor

Answer: B. The Wayback Machine keeps dated snapshots for years.

- A is wrong: the Google cache holds only a recent copy and drops deleted pages quickly.
- C is wrong: SHODAN indexes device banners, not old web pages.
- D is wrong: ExoneraTor checks whether an IP was a Tor relay.

Q7. Which tool can retrieve archived URLs of a target website from archive.org as part of a crawl?

- A. Photon
- B. Sherlock
- C. FOCA
- D. Maltego

Answer: A. Photon's --wayback option seeds the crawl with archive.org URLs.

- B is wrong: Sherlock finds usernames on social sites.
- C is wrong: FOCA extracts metadata from documents.
- D is wrong: Maltego builds relationship graphs.

Q8. A job ad from the target says "Experience with Cisco ASA 5506-X, VMware ESXi 6.5 and Windows Server 2012 R2 required". Why does this matter to an attacker?

- A. It gives the network block of the company
- B. It reveals the company's technology stack and likely vulnerable versions
- C. It gives employees' passwords
- D. It reveals the company's DNS records

Answer: B. Job sites reveal infrastructure details that help identify vulnerabilities.

- A is wrong: netblocks come from Whois or RIRs.
- C is wrong: job ads do not list passwords.
- D is wrong: DNS records come from DNS interrogation.

Q9. An investigator sees connections to a web server from 185.220.101.5 and wants to know whether that IP was a Tor relay on that date. Which tool should she use?

- A. Tor Browser
- B. ExoneraTor
- C. IP2Location
- D. DNSdumpster

Answer: B. ExoneraTor answers whether an IP was a Tor relay on a given date.

- A is wrong: Tor Browser is for browsing anonymously, not for checking relay history.
- C is wrong: IP2Location gives location and ISP, not Tor relay status.
- D is wrong: DNSdumpster maps DNS hosts.

Q10. Competitive intelligence gathering is BEST described as:

- A. Intrusive collection of competitor data using malware
- B. Non-interfering and subtle collection and analysis of information about competitors
- C. Scanning competitor networks for open ports
- D. Bribing competitor employees for documents

Answer: B. The slide defines it as identifying, gathering, analyzing, verifying, and using competitor information; it is non-interfering and subtle.

- A, C, and D are wrong: they are intrusive or illegal and interfere with the target.

Q11. An attacker wants to see building entrances, gates, security cameras, and weak spots in perimeter fences of a target campus before a physical test. Which tools from the module fit BEST?

- A. Google Earth, Google Maps, Wikimapia
- B. Google Finance, Yahoo! Finance
- C. Mention, Reputology
- D. Crunchbase, opencorporates

Answer: A. These are the tools listed for finding the geographical location of the target.

- B is wrong: financial services give stock and company finance data.
- C is wrong: these track online reputation.
- D is wrong: these are business profile sites.

Q12. A red team needs a list of public email addresses for microsoft.com to plan a phishing simulation. Which tool is designed for this?

- A. Sherlock
- B. theHarvester
- C. tracert
- D. whatweb

Answer: B. theHarvester collects emails and hosts from public sources.

- A is wrong: Sherlock searches usernames across social networks.
- C is wrong: tracert maps network routers.
- D is wrong: whatweb identifies web technologies.

Q13. Which tool searches a vast number of social networking sites for a single username and lists every site where it exists?

- A. BuzzSumo
- B. Social Searcher
- C. Sherlock

- D. Hashatit

Answer: C. Sherlock checks a username across hundreds of sites.

- A is wrong: BuzzSumo finds the most shared content.
- B is wrong: Social Searcher searches post content in real time.
- D is wrong: Hashatit searches hashtags.

Q14. A tester's IP Whois lookup shows that a target's address block is managed by the registry for Europe, the Middle East, and Central Asia. Which RIR is this?

- A. ARIN
- B. APNIC
- C. RIPE NCC
- D. LACNIC

Answer: C. RIPE NCC serves Europe, the Middle East, and Central Asia.

- A is wrong: ARIN serves North America.
- B is wrong: APNIC serves Asia Pacific.
- D is wrong: LACNIC serves Latin America and the Caribbean.

Q15. Which of the following is NOT normally returned by a Whois lookup?

- A. Domain name servers
- B. Domain expiry date
- C. Open TCP ports on the web server
- D. Contact details of the domain owner

Answer: C. Whois shows registration data, not open ports; ports come from scanning.

- A, B, and D are all on the slide's list of Whois results.

Q16. During DNS footprinting an attacker finds a record that lists the CPU type and operating system of a host. Which record type is it?

- A. TXT
- B. HINFO
- C. SOA
- D. SRV

Answer: B. HINFO (host information) includes CPU type and OS.

- A is wrong: TXT holds unstructured text such as SPF.
- C is wrong: SOA shows the authority for the zone.
- D is wrong: SRV lists services.

Q17. A tester has the IP range 162.241.216.0/24 and wants the host names for each IP using DNSRecon. Which command is BEST?

- A. dnsrecon -d 162.241.216.0/24 -t std
- B. dnsrecon -r 162.241.216.0/24
- C. dnsrecon -t axfr -d 162.241.216.0
- D. dnsrecon -D 162.241.216.0/24

Answer: B. -r with a range runs reverse (PTR) lookups across it.

- A is wrong: -d expects a domain name, and std queries standard records.
- C is wrong: axfr tests zone transfers for a domain.
- D is wrong: -D sets a word list file for brute force.

Q18. Which field in the IP header do traceroute programs change to discover each router on the path?

- A. Source port
- B. Checksum
- C. TTL
- D. Fragment offset

Answer: C. Traceroute raises the TTL by one per round; each router that drops a packet at TTL 0 replies with ICMP Time Exceeded.

- A is wrong: ports are not in the IP header, and the destination port only changes in UDP mode.
- B is wrong: the checksum is for error detection.
- D is wrong: fragment offset is for fragmentation.

Q19. From a Linux host, ICMP and UDP traceroutes to a web server stop at hop 5 with "* * *". The web site itself loads normally over HTTPS. What is the BEST next step to map the full path?

- A. Run traceroute -I again with more probes
- B. Run a TCP traceroute to port 443 (traceroute -T -p 443)
- C. Run tracert -d from the same Linux host
- D. Give up, because the host is down

Answer: B. The firewall allows HTTPS, so TCP SYN probes on 443 pass where ICMP and UDP are blocked.

- A is wrong: ICMP is already blocked; more probes will not help.
- C is wrong: tracert is a Windows command and uses ICMP.
- D is wrong: the site loads, so the host is up.

Q20. Traceroute results show: to 1.10.10.20 the second-to-last hop is 1.10.10.1; to 1.10.20.10 and 1.10.20.15 the second-to-last hop is 1.10.10.50 and the third-to-last is 1.10.10.1. What is 1.10.10.50 MOST likely?

- A. The bastion host
- B. The firewall in front of the DMZ
- C. The mail server
- D. The ISP's DNS server

Answer: B. It sits between the border router and the 1.10.20.x hosts only, so it is the firewall protecting that segment.

- A is wrong: the bastion host is 1.10.10.20, reached right after the router.
- C is wrong: the mail server is a destination (1.10.20.15), not a hop.
- D is wrong: nothing in the path suggests a DNS server.

Q21. Which part of an email gives the sender's IP address, the sender's mail server, and the authentication results?

- A. The subject line
- B. The email body
- C. The email header
- D. The attachment

Answer: C. The header (Received lines and Authentication-Results) holds these details.

- A, B, and D are wrong: they are content parts that the sender controls and do not carry routing data.

Q22. A tester posing as a courier waits near the reception desk and watches an employee type a door code. Which technique is this?

- A. Eavesdropping
- B. Shoulder surfing
- C. Dumpster diving
- D. Impersonation only

Answer: B. Watching someone enter data is shoulder surfing. (Posing as a courier is impersonation, but the information was gained by watching.)

- A is wrong: eavesdropping is listening to conversations.
- C is wrong: dumpster diving is searching trash.
- D is wrong: the disguise helped, but the question asks how the code was obtained.

Q23. An analyst wants a visual graph that links a target domain to its owners, email addresses, mail servers, and related organizations using "transforms". Which tool fits BEST?

- A. Recon-ng
- B. Maltego
- C. OSINT Framework
- D. subfinder

Answer: B. Maltego uses entities and transforms to build relationship graphs.

- A is wrong: Recon-ng is a CLI module framework without a link graph.
- C is wrong: OSINT Framework is a directory of tools.
- D is wrong: subfinder lists sub-domains only.

Q24. In Recon-ng, a tester types the two commands below. What happens?

```
[recon-ng][CEH] > modules load recon/domains-hosts/brute_hosts
[recon-ng][CEH][brute_hosts] > run
```

- A. A port scan of all hosts in the CEH workspace
- B. Brute-force guessing of host names for the source domain, storing found hosts
- C. A zone transfer from the domain's name server
- D. Installation of all marketplace modules

Answer: B. brute_hosts tries common host names against the domain and saves any that resolve.

- A is wrong: brute_hosts does not scan ports.
- C is wrong: zone transfer is a different technique.
- D is wrong: that is marketplace install all.

Q25. In OSINT Framework, a tool is marked (T). What does this mean?

- A. The tool is a Google dork
- B. The tool requires registration
- C. The tool must be installed and run locally
- D. The URL must be edited manually

Answer: C. (T) marks a tool that must be installed and run locally.

- A is wrong: that is (D).
- B is wrong: that is (R).
- D is wrong: that is (M).

Q26. A company publishes hundreds of Word and PDF files. A tester wants usernames, software versions, and internal paths hidden in those files. Which tool is BEST?

- A. FOCA
- B. subfinder
- C. Sherlock
- D. DNSdumpster

Answer: A. FOCA finds documents on a domain and extracts their metadata.

- B is wrong: subfinder finds sub-domains.
- C is wrong: Sherlock finds usernames online, not in documents.
- D is wrong: DNSdumpster maps DNS hosts.

Q27. A tester types this into the terminal on Parrot OS. What is the role of --shell?

```
sgpt --chat footprint --shell "Use Sublist3r to gather a \
list of subdomains of the target organization eccouncil"
```

- A. It opens an SSH shell to the target
- B. It asks the LLM to return a shell command and offers to execute it
- C. It saves the chat history to a file called footprint
- D. It runs the prompt without internet access

Answer: B. --shell makes ShellGPT return a command and prompt [E]xecute, [D]escribe, [A]bort.

- A is wrong: sgpt does not open remote shells.
- C is wrong: --chat footprint names the session; it is not the shell option.
- D is wrong: sgpt needs access to the LLM API.

Q28. An ethical hacker wants an AI-powered open-source OSINT tool that gathers, analyzes, and interprets public data to identify potential threats and vulnerabilities. Which tool is BEST?

- A. OSS Insight
- B. Taranis AI
- C. ChatPDF
- D. Google Word Sniper

Answer: B. Taranis AI is the AI OSINT tool described this way.

- A is wrong: OSS Insight focuses on GitHub ecosystem analytics.
- C is wrong: ChatPDF chats with one PDF document.
- D is wrong: Google Word Sniper builds search queries.

Q29. Using dig, an attacker successfully lists every host in a company's DNS zone with one query. Which countermeasure would have prevented this BEST?

- A. Disable directory listings on web servers
- B. Restrict zone transfers to authorized secondary servers
- C. Use pseudonyms on forums
- D. Disable geo-tagging on cameras

Answer: B. A full host list from one query is an AXFR zone transfer; restricting it stops the leak.

- A is wrong: directory listings are a web server issue.
- C is wrong: pseudonyms protect personal identity on forums.
- D is wrong: geo-tagging affects photo metadata.

Q30. An attacker wants AI help to automate DNS lookups, Whois retrieval, and email enumeration for one domain in a single run. Which approach from the module fits BEST?

- A. Ask an LLM to create a custom Python script that runs these footprinting commands
- B. Use Google Trends
- C. Run tracert with -d
- D. Use the related: operator

Answer: A. The module shows generating a custom Python script with AI to automate several footprinting tasks.

- B is wrong: Google Trends shows search popularity.
- C is wrong: tracert maps network hops only.
- D is wrong: related: finds similar websites.

10. Flashcards

Q: What is reconnaissance (footprinting)? | A: The preparation phase where the attacker collects as much information as possible about the target before attacking.

Q: Passive vs active reconnaissance? | A: Passive = no direct interaction with the target; active = direct interaction (DNS interrogation, social engineering, scanning, enumeration).

Q: Three groups of information obtained in footprinting? | A: Organization, network, and system information.

Q: Which operator limits results to one domain? | A: site:

Q: Which operator shows Google's stored copy of a page? | A: cache:

Q: Which operator lists pages similar to a given page? | A: related:

Q: intitle: vs allintitle:? | A: intitle: needs one word in the title; allintitle: needs all words in the title.

Q: What is GHDB? | A: The Google Hacking Database, a public list of ready-made Google dorks.

Q: What does SHODAN search? | A: Internet-connected devices and their banners (webcams, routers, IoT, ICS).

Q: Which tools find sub-domains and web server OS? | A: Netcraft (sub-domains, OS, netblock) and DNSdumpster (hosts of a domain).

Q: What does the Wayback Machine provide? | A: Archived versions of websites over time (archive.org).

Q: Which tool retrieves archived URLs from archive.org? | A: Photon (--wayback).

Q: Three people search services on the slide? | A: Spokeo, Intelius, pipl.

Q: Three job sites on the slide? | A: Dice, LinkedIn, Glassdoor.

Q: What does Tor Browser do? | A: Gives anonymous access to the dark web by bouncing traffic through several relays.

Q: Competitive intelligence is described as? | A: Non-interfering and subtle; identify, gather, analyze, verify, use.

Q: Tools for monitoring targets using alerts? | A: Google Alerts, X Alerts, Giga Alerts.

Q: Tools for tracking online reputation? | A: Mention, ReviewPush, Reputology.

Q: theHarvester flags -d, -l, -b? | A: Domain, result limit, data source.

Q: What does BuzzSumo find? | A: The most shared content for a topic, author, or domain.

Q: What does Sherlock do? | A: Searches hundreds of social networking sites for a username.

Q: Who maintains Whois databases? | A: Regional Internet Registries (ARIN, AFRINIC, RIPE NCC, LACNIC, APNIC).

Q: Seven things Whois returns? | A: Domain details, owner contacts, name servers, NetRange, creation date, expiry, last updated.

Q: DNS record that maps IP to hostname? | A: PTR.

Q: DNS record with CPU type and OS? | A: HINFO.

Q: DNS record for responsible person? | A: RP.

Q: What can IP geolocation reveal? | A: Country, region, city, ZIP, time zone, connection speed, ISP, domain, IDD code, area code, mobile carrier, elevation.

Q: What does DNSRecon do? | A: DNS enumeration: standard records, zone transfer test, brute force, reverse lookup, SRV.

Q: How does traceroute find routers? | A: It raises TTL one by one; each router at TTL 0 replies with ICMP Time Exceeded.

Q: Default protocol of tracert vs Linux traceroute? | A: tracert = ICMP; traceroute = UDP.

Q: Four social engineering techniques in this module? | A: Eavesdropping, shoulder surfing, dumpster diving, impersonation.

Q: What does Maltego do? | A: Shows relationships and real-world links between people, organizations, domains, and infrastructure as a graph.

Q: What is Recon-ng? | A: A web reconnaissance framework with independent modules and database interaction.

Q: OSINT Framework indicators? | A: (T) local tool, (D) Google dork, (R) registration, (M) edit URL manually.

Q: FOCA stands for? | A: Fingerprinting Organizations with Collected Archives; it extracts metadata from documents.

Q: What is subfinder? | A: A passive sub-domain discovery tool.

Q: What is Taranis AI? | A: An AI-powered open-source OSINT tool that gathers, analyzes, and interprets public data.

Q: What is OSS Insight? | A: An AI tool for insights into the GitHub ecosystem, analyzing over 5 billion GitHub events.

Q: Best countermeasure against DNS zone transfer leaks? | A: Restrict zone transfers to authorized servers; use split DNS.

Q: Countermeasure for photo location leaks? | A: Disable geo-tagging on cameras; turn off geolocation on mobile devices.

11. Glossary

- **Active reconnaissance:** information gathering with direct interaction with the target.
- **AFRINIC:** the RIR for Africa.
- **APNIC:** the RIR for the Asia Pacific region.
- **archive.org:** the Internet Archive; home of the Wayback Machine.
- **ARIN:** the RIR for North America.
- **AXFR:** a full DNS zone transfer.
- **Banner:** the text a service returns on connection, often with product and version.
- **Bastion host:** a hardened server directly exposed to the internet.
- **BuzzSumo:** a tool that finds the most shared content for a topic, author, or domain.
- **cache: operator:** shows Google's stored copy of a page.
- **CNAME:** a DNS alias record.
- **Competitive intelligence:** legal, subtle gathering and analysis of information about competitors.
- **Dark web:** hidden services reachable only with tools such as Tor.
- **Deep web:** content that search engines do not index.
- **DMZ:** a buffer network for public-facing servers.
- **DNS interrogation:** querying DNS servers for a target's records.
- **DNSdumpster:** an online tool that discovers hosts related to a domain.
- **DNSRecon:** a DNS enumeration tool.
- **DNSSEC:** digital signatures that protect DNS answers.
- **Dork:** a search query that uses operators to find sensitive data.
- **Dumpster diving:** searching trash for useful information.
- **Eavesdropping:** secretly listening to conversations or reading messages.
- **Email header:** hidden routing and technical data of an email.
- **Email tracking:** monitoring when and where an email is opened.
- **Entity (Maltego):** one object on the graph, such as a domain or person.
- **ExoneraTor:** a Tor Project service that checks whether an IP was a Tor relay.
- **filetype: operator:** limits results to a file type.
- **FOCA:** a tool that extracts metadata from documents.
- **Footprinting:** another name for reconnaissance.
- **Geo-tagging:** GPS coordinates stored in photo metadata.
- **GHDB:** Google Hacking Database.
- **Google hacking:** using advanced Google operators to find sensitive information.
- **HINFO:** a DNS record with CPU type and OS.
- **Impersonation:** pretending to be someone trusted.
- **inurl: operator:** finds pages with a word in the URL.
- **IP geolocation:** mapping an IP to a location and ISP.
- **LACNIC:** the RIR for Latin America and the Caribbean.

- **Maltego:** a link-analysis tool that builds relationship graphs.
- **Metadata:** data about a file, such as author and software.
- **MX:** a DNS record naming the mail server.
- **Netblock:** a range of IP addresses owned by one organization.
- **Netcraft:** a service that lists sites, sub-domains, and hosting OS.
- **NetRange:** an IP range shown in Whois results.
- **NS:** a DNS record naming the domain's name server.
- **OSINT:** open-source intelligence from public sources.
- **OSINT Framework:** a web tree of free OSINT tools.
- **OSS Insight:** an AI tool for GitHub ecosystem insights.
- **Passive reconnaissance:** information gathering without direct interaction.
- **Photon:** a web crawler that can use archive.org URLs.
- **Pseudonym:** a made-up name used online.
- **PTR:** a DNS record that maps an IP to a hostname.
- **Recon-ng:** a modular web reconnaissance framework.
- **Reverse DNS lookup:** finding the hostname for an IP.
- **RIPE NCC:** the RIR for Europe, the Middle East, and Central Asia.
- **RIR:** Regional Internet Registry.
- **RP:** a DNS record naming the responsible person.
- **SHODAN:** a search engine for internet-connected devices.
- **ShellGPT (sgpt):** a command-line LLM client.
- **Sherlock:** a username search tool for social networks.
- **Shoulder surfing:** watching someone's screen or keyboard.
- **site: operator:** limits results to one domain.
- **SOA:** a DNS record that shows the authority for a zone.
- **Social engineering:** exploiting human behavior to get information.
- **Split DNS:** separate internal and external DNS views.
- **SRV:** a DNS service record.
- **Sub-domain:** a name under the main domain, such as mail.example.com.
- **subfinder:** a passive sub-domain discovery tool.
- **Sublist3r:** a sub-domain enumeration tool with brute force.
- **Taranis AI:** an AI-powered OSINT tool.
- **theHarvester:** a tool that gathers emails and hosts.
- **TLD:** top-level domain, such as .com.
- **Tor:** an onion-routing network for anonymity.
- **Traceroute:** a tool that maps routers on a path using TTL.
- **Transform (Maltego):** an action that finds entities related to another entity.
- **TTL:** Time To Live; a hop counter in the IP header.
- **TXT:** a DNS record that holds free text, such as SPF.
- **Wayback Machine:** archive.org's store of old website snapshots.
- **Whois:** a protocol and database for domain and IP registration data.
- **Wildcard DNS:** DNS that answers any sub-domain name.
- **Zone transfer:** copying all DNS records of a zone to another server.

12. Coverage Report

12.1 Page to Section Map

PDF page	Slides (topics)	Guide sections
1	2 objectives, 4 recon types, 5 info obtained	3.1, 3.2, 3.3
1	6 methodology, 8 Google operators, 7 engines	3.4, 3.5, 3.6
2	9 Google hacking with AI, 11 SHODAN	3.7, 3.8
3	Google webcam demo (natural language, inurl:)	3.9
4	15 TLDs and sub-domains, 16 with AI	3.10, 3.11
5	17 archive.org and Photon, 18 people and job sites	3.12, 3.13
6	19 dark web, 20 competitive intelligence	3.14, 3.15
7	21 other research techniques, 24 email with AI	3.16, 3.17
8	25 social media presence, 26 Sherlock and Social Searcher	3.18, 3.19
9	27 social with AI, 30 and 29 Whois	3.20, 3.21
9	32 DNS records, 31 IP geolocation	3.22, 3.23
10	34 DNSRecon with AI, 35 reverse DNS	3.24, 3.25
10	37 traceroute, 38 with AI, 39 analysis	3.26, 3.27, 3.28
11	40 email tracking, 42 social engineering	3.29, 3.30
11	46 Maltego and Recon-ng	3.31
12	48 OSINT Framework, 43 SE on social sites	3.32, 3.33
13	47 FOCA and subfinder, 49 AI OSINT tools	3.34, 3.35
14	52 countermeasures, custom Python with AI, 53	3.36, 3.37, 3.38

Tools, commands, ports, and terms from all pages also appear in sections 4 to 11.

12.2 [UNCLEAR] Items

1. Page 2: the exact command generated by ShellGPT for the filetype:pdf prompt (best reading: lynx --dump plus grep and cut, saved to recon1.txt).
2. Page 2: the two SHODAN search keywords (best reading: a webcam search and a camera or RTSP search; top port 554 in the second).
3. Page 4: the exact commands generated for the dig and Sublist3r prompts.
4. Page 7: the theHarvester version number and exact email and host counts in the AI demo.
5. Page 9: the name of the second Whois tool on slide 30 (best reading: a desktop Whois client such as SmartWhois or Batch IP Converter).
6. Page 9: the full list of DNS interrogation tools on slide 32 (SecurityTrails and DNSChecker are clear; Fierce and zdns are a best reading).
7. Page 10: the exact command lines on the traceroute slides (37, 38) and the name of the "Reverse Lookup" web tool (appears to be MxToolbox).
8. Page 12: the leaf tool names in the OSINT Framework tree.
9. Page 14: the exact prompt text of the custom Python script slide.

12.3 Items to Double Check

- Google has retired the cache: operator, and link: and info: are limited; the exam may still test their meanings.
- The archive.org snapshot count (297,283) and date range for microsoft.com.
- theHarvester flags in your version (-t and -r changed meaning in newer releases).
- DNSRecon -t rvl usage with -r, and whatweb aggression levels.
- The ExoneraTor description and other dark web tools (added context).
- The descriptions of Sudomy, BillCipher, Raccoon, Recon-Dog, Web Check, OSINT.SH, DorkGPT, DorkGenius, Google Word Sniper, and Cylect.io (the slides give only names and URLs).
- The SHODAN name expansion.

12.4 Confirmation

Every line of the working inventory (pages 1 to 14, 40 screenshots) is mapped to a section in the table above. Items that could not be read with certainty are listed in 12.2 with a best reading, and outside knowledge is labeled ADDED CONTEXT.